BURKINA FASO

La Patrie ou la Mort, nous Vaincrons

HACKATHON 226 – ÉDITION 2026

Sprint technique pré-hackathon – « Solutions open source endogènes »

CAHIER DES CHARGES

SovereignMsg

Messagerie instantanée souveraine de l'administration publique burkinabè

Type de document	Cahier des charges fonctionnel et technique, avec étude préliminaire et étude de faisabilité
Challenge	« La messagerie souveraine de l'administration » – MTDPCE / DGTD
Version	2.0 – Novembre 2026
Licence du code	Apache 2.0 (licence des dépendances du client vérifiée, voir section 5.3)
Niveau d'engagement open source	Créer (application nouvelle reposant sur des bibliothèques éprouvées)
Équipe	[Nom de l'équipe] – [Université] – [Filière et niveau de chaque membre]
Date limite de dépôt	1er novembre 2026

TABLE DES MATIÈRES

1. Présentation générale et étude préliminaire 4
1.1 Origine et cadre 4
1.2 Problématique 4
1.3 Étude de l'existant 4
1.4 Analyse des besoins 5
1.5 Positionnement 6
1.6 Analyse PESTEL 6
2. Vision, objectifs et piliers 8
2.1 Les quatre piliers 8
2.2 Objectifs mesurables 8
3. Cibles et acteurs 9
3.1 Cibles 9
3.2 Acteurs du système 9
3.3 Profils types 10
3.4 Matrice des droits 11
4. Périmètre et contraintes 11
4.1 Périmètre inclus et exclu 11
4.2 Contraintes du règlement et réponse du projet 12
4.3 Calendrier officiel 12
4.4 Type d'application : application web progressive (PWA) 12
5. Étude de faisabilité 13
5.1 Choix du protocole de chiffrement 13
5.2 Faisabilité par dimension 14
5.3 Licences 15
5.4 Plans de repli 15
5.5 Verdict 16
6. Innovation 16
6.1 Axes d'innovation retenus 16
6.2 Fonction principale : la classification des messages 16
6.3 Limites assumées 16
7. Spécifications fonctionnelles 17
7.1 Identité et accès 17
7.2 Messagerie 17
7.3 Fichiers 17
7.4 Groupes 18
7.5 Révocation 18
7.6 Administration 18
7.7 Innovation 19
8. Exigences non fonctionnelles 19
9. Architecture technique 20
9.1 Vue d'ensemble 20
9.2 Composants et licences 21
9.3 Parcours d'un message chiffré 22
9.4 Parcours de révocation 23
9.5 Modèle de données de la passerelle 23
9.6 Interfaces de la passerelle 26
9.7 Déploiement 27
9.8 Métadonnées visibles par le serveur et mesures de réduction 27
9.9 Modèle de menaces 28
9.10 Front-office et back-office 29
9.11 Sécurité sur tout le cycle de vie 31
10. Pages et écrans de l'application 34
10.1 Principes d'ergonomie 36
11. Plan de test et préparation des épreuves en direct 36
11.1 Tests automatisés (bonus de 2 points) 37
11.2 Liste de vérification avant dépôt 37
12. Planning et organisation 37
12.1 Planning du sprint 37
12.2 Répartition des rôles 38
12.3 Compréhension du code 39
13. Gestion des risques 39
14. Livrables et conformité 40

14.1 Contenu du README (deux pages au maximum)....40
14.2 Plan de la note de sécurité (deux pages)....40
15. Grille d'auto-évaluation....40
16. Conclusion et recommandations....41
Annexe A – Note Synapse et squelette du README....42
A.1 Texte de précision (à reprendre tel quel dans le README et le dossier)....42
A.2 Squelette du README (deux pages au maximum, en français)....42
Annexe B – Révocation en direct et inspection de la base....42
B.1 Configuration obligatoire de Synapse....42
B.2 Protocole de test de la révocation (épreuve du jury)....43
B.3 Requêtes SQL d'inspection de la base Synapse....44
B.4 Autres preuves à montrer....44
Annexe C – Fiches d'explication du code....44
Annexe D – Glossaire....45

1. Présentation générale et étude préliminaire

1.1 Origine et cadre

Dans le cadre de la Semaine du Numérique 2026, le Ministère de la Transition Digitale, des Postes et des Communications Électroniques (MTDPCE), par sa Direction Générale de la Transformation Digitale (DGTD), organise le Hackathon 226 – Édition 2026. Un sprint technique pré-hackathon sélectionne seize (16) équipes finalistes parmi les étudiants des établissements d'enseignement supérieur du Burkina Faso.

Toutes les équipes traitent un challenge unique : concevoir et réaliser une messagerie instantanée (messages, groupes, fichiers) destinée aux agents de l'administration publique, hébergeable sur l'infrastructure de l'État et offrant un niveau de sécurité élevé. Un socle de sécurité est obligatoire et non négociable ; tout le reste est libre.

1.2 Problématique

Les agents publics échangent chaque jour des informations de service, parfois sensibles, sur des messageries grand public dont les serveurs et les règles d'exploitation échappent à l'État. Le tableau suivant résume les risques identifiés.

Problème	Description	Conséquence pour l'État
Perte de souveraineté	Serveurs hébergés à l'étranger, règles d'exploitation décidées par un tiers	Données soumises à des législations extraterritoriales
Exploitation des métadonnées	Qui parle à qui, quand, depuis où	Cartographie des relations internes de l'administration
Confidentialité non garantie	Chiffrement de bout en bout non systématique selon l'outil, sauvegardes en ligne non maîtrisées	Contenus lisibles par des tiers dans certains cas
Fuite d'informations de service	Instructions, données personnelles et documents internes sur des canaux non maîtrisés	Atteinte à la vie privée des usagers et au secret professionnel
Absence d'audit	Le code des applications utilisées ne peut être ni vérifié ni audité	Impossibilité de prouver l'absence de porte dérobée
Départ d'un agent ou perte d'un téléphone	Aucun moyen de couper l'accès aux conversations de service	Accès persistant d'une personne qui ne doit plus en disposer

1.3 Étude de l'existant

Cette étude compare des solutions courantes ou de référence aux exigences du challenge. Les appréciations sont qualitatives et reflètent l'état général connu de ces solutions ; elles doivent être revérifiées à la date du dépôt.

Solution	Chiffrement de bout en bout	Code ouvert	Hébergement par l'État	Enrôlement contrôlé	Adéquation au challenge
WhatsApp	Oui pour les messages	Non	Non	Non (numéro de téléphone)	Faible : aucune maîtrise du serveur

Solution	Chiffrement de bout en bout	Code ouvert	Hébergement par l'État	Enrôlement contrôlé	Adéquation au challenge
Telegram	Partiel (conversations secrètes uniquement)	Partiel (clients)	Non	Non	Faible
Signal	Oui	Oui	Difficile (serveur complexe, dépendances externes)	Non (numéro de téléphone)	Moyenne : excellente cryptographie, déploiement lourd
Matrix / Element	Oui (Olm / Megolm)	Oui	Oui (Synapse, Docker)	Configurable	Élevée : base technique retenue
XMPP / OMEMO (Conversations)	Oui (OMEMO)	Oui	Oui	Configurable	Moyenne à élevée : écosystème navigateur moins mature
Tchap (administration française)	Oui	Oui	Oui (instance d'État)	Oui (adresses officielles)	Référence : prouve la viabilité d'une messagerie d'État fondée sur Matrix

1.4 Analyse des besoins

Besoin exprimé	Source	Réponse de SovereignMsg
Messagerie aussi simple que celles du marché	Énoncé du challenge	Interface familière : liste de conversations, fil de messages, groupes, pièces jointes
Contenu illisible par le serveur	Socle de sécurité	Chiffrement de bout en bout via un protocole éprouvé ; le serveur ne stocke que du texte chiffré
Hébergement maîtrisé, sans service tiers	Socle de sécurité	Docker Compose, aucune ressource externe, installation en une commande
Seuls les agents autorisés entrent	Socle de sécurité	Inscription publique désactivée, enrôlement par un administrateur, second facteur TOTP
Couper l'accès d'un agent partout, tout de suite	Socle de sécurité	Révocation : désactivation du compte, suppression des appareils et des jetons, rotation des clés de groupe
Connaître ce que le serveur voit malgré tout	Socle de sécurité	Tableau des métadonnées visibles et mesures de réduction (section 9.8)
Fonctionner en zone mal couverte	Contexte national, espace d'innovation	Mode faible connexion : file d'envoi différé et compression avant chiffrement
Utilisable dans une langue nationale	Espace d'innovation, bonus	Interface partiellement traduite en mooré ou en dioula

Hypothèses à valider. Les besoins ci-dessus proviennent de l'énoncé officiel et du contexte public ; aucune enquête de terrain n'a été menée dans le cadre du sprint. Le retour d'agents réels est une étape ultérieure, hors périmètre du prototype (le règlement n'autorise que des comptes et des données fictifs).

1.5 Positionnement

SovereignMsg est une messagerie d'administration qui associe trois choses rarement réunies dans un prototype étudiant : un protocole de chiffrement déjà éprouvé (aucune cryptographie maison), un contrôle d'identité de niveau administration (enrôlement, second facteur, rôles, révocation) et des fonctions pensées pour le contexte burkinabè (classification des messages, faible connexion, langue nationale).

1.6 Analyse PESTEL

L'analyse PESTEL (politique, économique, social, technologique, environnemental, légal) situe SovereignMsg dans son environnement burkinabè. Chaque facteur est relié à son effet sur le projet et à la réponse retenue. Les chiffres viennent de sources publiques consultées le 1er novembre 2026 (DataReportal, Ecofin, Commission de l'informatique et des libertés, ANSSI, Pacte national de l'énergie) ; ils sont donnés à titre indicatif.

Facteur	Constat	Effet	Réponse de SovereignMsg
Politique	Le numérique est une priorité de l'État : le budget de fonctionnement 2026 du ministère chargé du numérique a été porté à 61 milliards de FCFA, soit le double de 2025, et la souveraineté numérique est au cœur de la Semaine nationale de lutte contre la cybercriminalité (octobre 2025).	Opportunité	Le challenge du MTDPCE et de la DGTD s'inscrit dans cette orientation. Le service s'installe sur un serveur maîtrisé par l'État, sans appel vers un service tiers et sans dépendance à un magasin d'applications.
Politique	Le contexte sécuritaire impose une grande vigilance sur la confidentialité des échanges publics ; la CIL traite elle-même de la protection des données « dans un contexte de crise sécuritaire » (séminaire de Kaya, juin 2024).	Contrainte	Chiffrement de bout en bout, classification des messages, révocation immédiate d'un appareil perdu ou volé, journal d'audit consultable par le RSSI.
Économique	Les composants retenus n'imposent aucun coût de licence (Apache 2.0 ; Synapse sous AGPL-3.0, utilisé sans modification). Un serveur de 2 vCPU et 4 Go de mémoire suffit pour 50 utilisateurs.	Opportunité	Une seule base de code (PWA) évite de financer plusieurs applications ; aucun frais de publication sur les magasins ; déploiement en une commande.
Économique	Le coût réel d'une solution se joue dans l'exploitation (mises à jour, sauvegardes, supervision), souvent sous-estimée dans les projets numériques publics.	Menace	Procédures d'exploitation simples et documentées (sections 9.7 et 9.11), redémarrage automatique des conteneurs, exploitation possible par un seul administrateur.
Social	Le mobile domine : 29,3 millions de connexions mobiles fin 2025 (121 % de la population) pour 5,42 millions d'internautes (22,4 %) selon DataReportal. Les abonnements ne mesurent pas des personnes distinctes.	Opportunité et contrainte	Interface pensée d'abord pour le téléphone (largeur 360 px), envoi d'un message en trois actions, installation de l'application en un geste depuis le navigateur.

Facteur	Constat	Effet	Réponse de SovereignMsg
Social	La protection des données reste méconnue des agents : la CIL l'a constaté lors de ses journées de mars 2025 et a été chargée de sensibiliser l'administration. Le français cohabite avec le mooré et le dioula.	Menace	Trois niveaux de classification faciles à comprendre, messages d'erreur clairs, bascule vers une langue nationale (EF-62), fiches pédagogiques. Le TOTP et la révocation limitent les conséquences d'une erreur humaine.
Technologique	La couverture reste inégale : l'État étend le réseau (370 localités raccordées en 2025, environ 1 000 localités visées en 2026). Un agent en service déconcentré dépend d'une connexion instable.	Contrainte	PWA avec cache de l'interface, file d'envoi différée (EF-63), compression des images avant chiffrement, indicateur d'état de la connexion.
Technologique	Un écosystème de sécurité se structure : ANSSI créée en 2013, centre de réponse aux incidents (CIRT), loi sur la sécurité des systèmes d'information adoptée en juillet 2024, centre de supervision des infrastructures numériques lancé en janvier 2026.	Opportunité	Journal d'audit et documentation de sécurité exploitables par un auditeur ; architecture simple à faire examiner par l'ANSSI.
Technologique	Des briques libres et éprouvées existent : protocole Matrix, chiffrement Olm et Megolm, bibliothèque vodozemac, serveur Synapse.	Opportunité	Aucune cryptographie maison ; l'effort porte sur l'identité, la révocation et l'audit.
Environnemental	L'accès à l'électricité concernait 34,2 % de la population en 2024 selon le Pacte national de l'énergie (juin 2026), environ 10 % en milieu rural ; des délestages surviennent en période de forte demande. Un programme de 104 milliards de FCFA, approuvé en septembre 2026, vise 70 % en 2030.	Contrainte	Redémarrage automatique et sauvegardes ; recommandation d'un onduleur ou d'une alimentation solaire pour le serveur ; messages mis en file d'attente côté client en cas de coupure.
Environnemental	Les téléphones des agents sont de gammes variées, et leur renouvellement a un coût financier et écologique.	Opportunité	Client web léger fonctionnant sur un navigateur récent, aucune ressource externe chargée, consommation de données limitée.
Légal	Loi n° 001-2021/AN du 30 mars 2021 sur la protection des personnes à l'égard du traitement des données à caractère personnel, contrôlée par la CIL : formalités préalables, minimisation, sécurité.	Contrainte	Données personnelles limitées au nécessaire (nom, ministère, fonction, rôle) ; contenu des messages inaccessible au serveur ; durées de conservation configurables ; l'administration, responsable du traitement, accomplit les formalités auprès de la CIL avant tout usage réel.
Légal	Loi portant sécurité des systèmes d'information (adoptée le 9 juillet 2024) et rôle de l'ANSSI : exigences applicables aux systèmes de l'État.	Contrainte	Authentification forte, journalisation, moindre privilège, sécurité sur tout le cycle de vie (section 9.11), prêt pour un audit.

Facteur	Constat	Effet	Réponse de SovereignMsg
Légal	Règlement du hackathon : licence reconnue par l'OSI, données fictives uniquement, aucun test d'intrusion sur un système réel.	Contrainte	Apache 2.0 (section 5.3), comptes fictifs, tests uniquement sur l'instance de démonstration.
Légal	Les échanges de l'administration peuvent relever d'obligations d'archivage ou de réquisition, alors que le chiffrement de bout en bout interdit toute lecture par le serveur. Point à valider avec le service juridique de l'administration.	Point ouvert	Archivage légal exclu du prototype et noté comme piste d'évolution (section 4.1) : archivage décidé par les participants à la conversation.

Lecture d'ensemble. Les facteurs politiques, juridiques et institutionnels sont favorables et justifient le projet. Les contraintes dominantes (connectivité inégale, électricité instable, culture de la protection des données encore en construction) expliquent quatre choix techniques : une application web progressive (section 4.4), un mode faible connexion, un redémarrage automatique avec sauvegardes, et une interface simple à trois niveaux de classification.

2. Vision, objectifs et piliers

2.1 Les quatre piliers

Pilier	Promesse	Mécanisme
Confidentialité	Seuls l'expéditeur et les destinataires lisent les messages et les fichiers	Chiffrement de bout en bout (Olm / Megolm) ; clés privées uniquement sur l'appareil
Souveraineté	Le service s'installe sur un serveur maîtrisé, sans dépendance externe	Docker Compose, composants open source, aucun appel vers un service tiers
Identité vérifiée	Seuls les agents enrôlés entrent, avec une authentification forte	Enrôlement administrateur, mot de passe Argon2id, TOTP, rôles
Révocation immédiate	Un agent révoqué perd tout accès sur tous ses appareils	Désactivation du compte, jetons supprimés, rotation des clés de groupe

2.2 Objectifs mesurables

Réf.	Objectif	Indicateur de réussite
OBJ-1	Aucun message ni fichier en clair côté serveur	0 contenu lisible dans la base de données et dans le trafic réseau (inspection par le jury)
OBJ-2	Déploiement reproductible	Une commande suffit sur une machine vierge ; démarrage complet en moins de 5 minutes
OBJ-3	Révocation visible en direct	Accès de l'agent révoqué coupé en quelques secondes, y compris pour les nouveaux messages
OBJ-4	Intrus rejeté	Un compte non enrôlé ne peut ni s'inscrire, ni se connecter, ni être invité
OBJ-5	Une innovation démontrée	Message « Confidentiel » démontré en moins de 60 secondes

Réf.	Objectif	Indicateur de réussite
OBJ-6	Équipe capable d'expliquer son code	Chaque membre explique les fonctions d'authentification et de chiffrement sans aide
OBJ-7	Score visé	87 points sur 100 (section 15)

3. Cibles et acteurs

3.1 Cibles

Cible	Description	Besoin principal	Priorité
Agents de l'administration publique	Agents des ministères, directions et services déconcentrés	Échanger vite et en sécurité, depuis un téléphone ou un ordinateur	Cible principale
Administrateurs système de l'État	Personnel chargé du déploiement, de l'enrôlement et de la maintenance	Installer simplement, enrôler et révoquer sans intervention technique lourde	Cible principale
Responsables de la sécurité (RSSI)	Auditeurs et validateurs de la solution	Vérifier l'absence de clair côté serveur, consulter le journal, comprendre les limites	Cible secondaire
Invités restreints	Prestataires ou partenaires ponctuels	Participer à une conversation précise sans accès au reste	Cible secondaire
Jury du Hackathon	Évaluateurs du dossier et de l'entretien	Tester rapidement le socle de sécurité et l'innovation	Cible d'évaluation

3.2 Acteurs du système

La figure 1 présente les acteurs humains et les cas d'usage. Les acteurs techniques (client navigateur, passerelle d'identité, serveur Matrix, base de données) sont décrits en section 9.

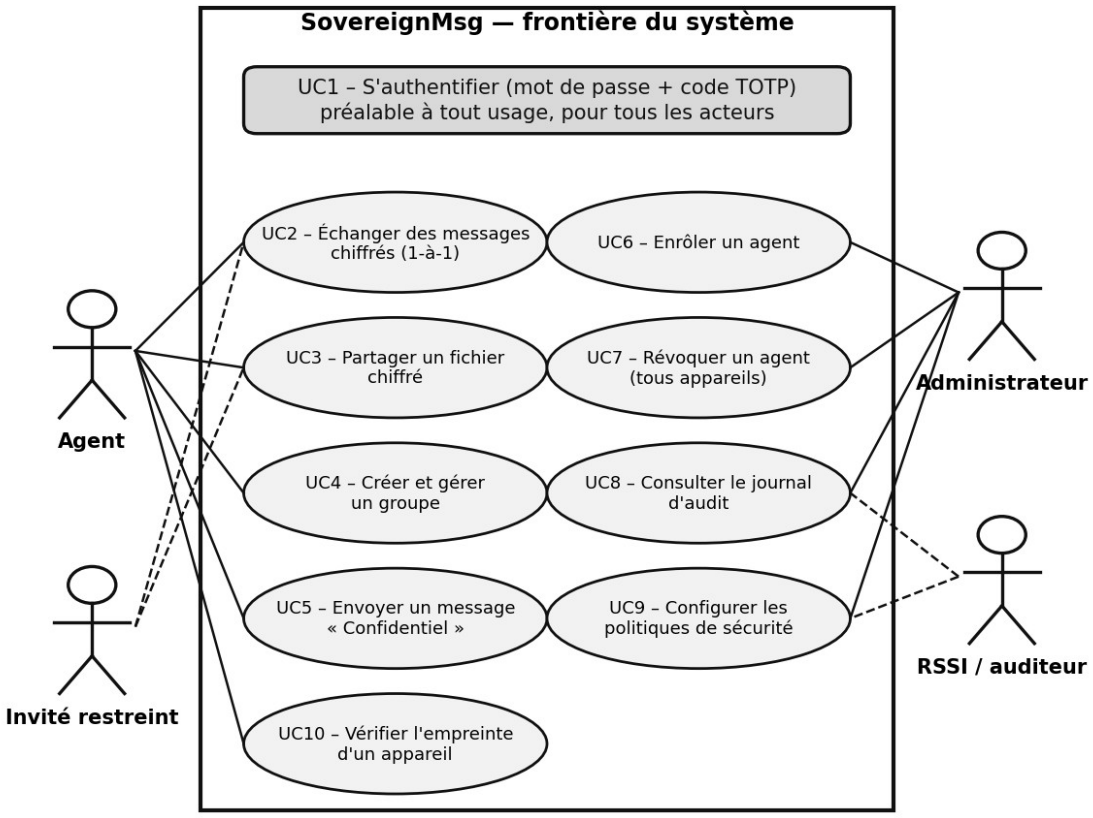


Figure 1 – Acteurs et cas d'usage de SovereignMsg

Acteur	Rôle dans le système	Compte requis	Authentification
Administrateur	Enrôle et révoque les agents, change les rôles, configure les politiques, consulte l'audit	Oui (rôle Administrateur)	Mot de passe + TOTP
Agent	Envoie des messages, crée des groupes, partage des fichiers, vérifie les appareils	Oui, après enrôlement	Mot de passe + TOTP
Invité restreint	Participe uniquement aux conversations auxquelles il est invité	Oui, créé par un administrateur	Mot de passe + TOTP
RSSI / auditeur	Lecture du journal d'audit et de la configuration, sans pouvoir d'action	Oui (lecture seule)	Mot de passe + TOTP
Intrus (acteur hostile)	Tente de s'inscrire, de se connecter ou de rejoindre un groupe sans enrôlement	Non	Rejeté à toutes les étapes

3.3 Profils types

Profil	Contexte	Besoin	Fonction qui répond
Chef de service, ministère (Ouagadougou)	Diffuse des instructions de service à une équipe de 20 agents	Savoir que seul son équipe lit, classer l'instruction « Confidentiel »	Groupes, message Confidentiel
Agent d'un service déconcentré (connexion instable)	Réseau mobile irrégulier, rédaction de messages hors couverture	Ne pas perdre ses messages, limiter la consommation de données	Mode faible connexion

Profil	Contexte	Besoin	Fonction qui répond
Administrateur système	Un seul serveur, peu de temps	Installer en une commande, couper un accès perdu ou volé	Docker Compose, révocation, audit

3.4 Matrice des droits

Action	Administrateur	Agent	Invité restreint	RSSI
S'authentifier (mot de passe + TOTP)	Oui	Oui	Oui	Oui
Envoyer un message direct ou de groupe	Oui	Oui	Oui (conversations invitées)	Non
Partager un fichier chiffré	Oui	Oui	Limité (taille et type)	Non
Créer un groupe, ajouter ou retirer des membres	Oui	Oui	Non	Non
Envoyer un message « Confidentiel »	Oui	Oui	Non	Non
Consulter l'annuaire des agents	Oui	Oui	Non	Non
Enrôler un agent	Oui	Non	Non	Non
Révoquer un agent ou changer un rôle	Oui	Non	Non	Non
Consulter le journal d'audit	Oui	Non	Non	Oui (lecture)
Modifier la configuration	Oui	Non	Non	Lecture seule

4. Périmètre et contraintes

4.1 Périmètre inclus et exclu

Inclus dans le prototype	Exclu du prototype
Messages directs (1-à-1) et messages de groupe	Appels audio et vidéo
Partage de fichiers chiffrés (10 Mo par défaut, configurable)	Applications natives mobiles ou de bureau (le prototype est une application web progressive, section 4.4)
Chiffrement de bout en bout par un protocole éprouvé	Fédération entre instances
Authentification forte : mot de passe + TOTP	Archivage légal (piste d'évolution)
Rôles : Administrateur, Agent, Invité restreint	Plusieurs organisations sur une même instance
Révocation immédiate sur tous les appareils	Notifications poussées par un service tiers (contraire à la souveraineté)
Hébergement souverain en une commande	Données réelles et tests d'intrusion sur un système réel (interdits)
Documentation des métadonnées et note de sécurité	
Au moins une fonction innovante démontrée	

4.2 Contraintes du règlement et réponse du projet

Règle du règlement	Réponse du projet
Code publié sous licence reconnue par l'OSI, fichier LICENSE à la racine	Apache 2.0 ; fichier LICENSE présent à la racine
Chaque technologie citée avec sa licence et son lien	Tableau des composants (section 9.2) repris dans le README
Aucun service tiers indispensable, gratuit ou payant	Tout est hébergé localement ; aucune police, aucun CDN, aucun suivi externe chargé
Niveau d'engagement déclaré (Contribuer, Étendre et adapter, Créer)	Créer : application nouvelle reposant sur des bibliothèques éprouvées
Aucune cryptographie développée par l'équipe (élimination)	Chiffrement délégué à la bibliothèque Matrix (vodozemac) ; revue de code interdisant tout appel direct à des primitives
Aucun message en clair côté serveur (élimination)	Inspection de la base avant chaque dépôt (section 11)
Seulement des comptes et des données fictifs	Script d'amorçage de comptes de démonstration fictifs
Pas de test d'intrusion sur un système réel	Tests uniquement sur l'instance locale de l'équipe
Commits Git progressifs pendant le sprint	Un commit au minimum par fonction livrée, historique couvrant toute la durée
Chaque membre comprend chaque ligne de code	Relecture croisée et fiches d'explication (section 12.3)

4.3 Calendrier officiel

Étape	Échéance
Publication du sprint technique	26 octobre 2026
Dépôt des dossiers et prototypes	Du 26 octobre au 1er novembre 2026
Tri sur dossier (65 points)	2 au 3 novembre 2026
Entretiens techniques (15 minutes, 35 points) des équipes présélectionnées	4 au 5 novembre 2026
Notification des seize équipes finalistes	6 novembre 2026
Hackathon national : 72 heures, projet dévoilé à l'ouverture	7 au 9 novembre 2026

4.4 Type d'application : application web progressive (PWA)

Nous avons fait le choix d'une application web progressive (PWA) plutôt qu'une application native. Cela nous permet de couvrir à la fois les ordinateurs de bureau de l'administration et les téléphones des agents, avec un seul code source. L'agent peut installer l'icône sur son téléphone sans passer par le Play Store, ce qui est plus rapide à déployer et plus souverain (pas de dépendance à Google ou Apple).

Un seul code, deux usages (web et mobile), zéro dépendance aux magasins d'applications.

Critère	PWA (retenue)	Application native	Site web classique
Code source	Un seul pour ordinateurs et téléphones	Un par plateforme (Android, iOS, ordinateur)	Un seul

Critère	PWA (retenue)	Application native	Site web classique
Distribution	Lien web ; installation depuis le navigateur	Magasins d'applications (compte développeur, validation, règles de la plateforme)	Lien web
Souveraineté	Aucune dépendance à Google ou Apple pour distribuer l'application	Dépendance aux magasins	Aucune dépendance
Mise à jour	Immédiate, côté serveur	Par le magasin, puis par l'utilisateur	Immédiate
Hors connexion	Cache et file d'envoi différée (service worker)	Possible	Très limité
Icône sur l'écran d'accueil	Oui, après installation	Oui	Non
Stockage des clés privées	IndexedDB du navigateur, isolé par origine	Coffre du système (mieux protégé)	Identique à la PWA
Charge pour deux personnes en six jours	Adaptée	Trop élevée (plusieurs bases de code)	Adaptée

Mise en œuvre dans le prototype

- Un manifeste d'application (nom, icônes, affichage autonome) et un service worker qui met en cache l'interface et tient la file d'envoi différée. Aucun contenu de message en clair n'est mis en cache.
- Accès uniquement en HTTPS, condition d'installation d'une PWA et déjà exigée par ENF-03.
- Installation : Chrome et Edge la proposent sur ordinateur et sur Android ; sur iPhone, l'agent utilise « Sur l'écran d'accueil » depuis Safari.

Limites assumées

- Les notifications poussées passent par le service du fabricant du navigateur ; elles sont exclues du prototype (section 4.1) pour préserver la souveraineté. L'application signale les nouveaux messages à l'ouverture. Piste d'évolution : une notification sans contenu.
- Les clés privées vivent dans le stockage du navigateur, moins protégé qu'un coffre natif. Atténuations : expiration de session, révocation, effacement local à la détection de la révocation (EF-44). Si l'agent efface les données du site, l'appareil doit être de nouveau autorisé selon la politique de clés (EF-13).

5. Étude de faisabilité

5.1 Choix du protocole de chiffrement

Le règlement impose un protocole parmi quatre : Signal (libsignal), Matrix (Olm / Megolm), MLS (OpenMLS) ou XMPP (OMEMO). Chacun a été noté de 1 (défavorable) à 5 (favorable) selon des critères de faisabilité en temps limité. Il s'agit d'une évaluation de l'équipe, à confirmer par un essai rapide.

Critère	Signal (libsignal)	Matrix (Olm / Megolm)	MLS (OpenMLS)	XMPP (OMEMO)
Maturité du protocole	5	5	4	4

Critère	Signal (libsignal)	Matrix (Olm / Megolm)	MLS (OpenMLS)	XMPP (OMEMO)
Bibliothèque utilisable dans un navigateur	2	5	3	3
Serveur auto-hébergeable prêt à l'emploi	1	5	1	4
Chiffrement des groupes	4	5	5	4
Faisabilité dans le temps imparti	1	4	1	3
Documentation et exemples	3	5	3	3
Total sur 30	**16**	**29**	**17**	**21**

Décision : Matrix (Olm / Megolm). Le serveur Synapse est prêt à l'emploi et s'installe avec Docker ; la bibliothèque cliente matrix-js-sdk, associée au module de chiffrement vodozemac compilé en WebAssembly, fournit le chiffrement des conversations directes (Olm) et des groupes (Megolm) sans qu'aucune ligne de cryptographie ne soit écrite par l'équipe.

> **Précision : Synapse est un logiciel libre auto-hébergé, pas un service commercial**
>
> SovereignMsg utilise **Matrix Synapse**, le serveur Matrix open source (licence AGPL-3.0), installé sur l'infrastructure de l'État avec le chiffrement de bout en bout activé par défaut pour tous les salons. Aucun service hébergé ou commercial n'est utilisé : ni compte sur un serveur public, ni offre payante d'un éditeur, ni passerelle externe. La fédération avec d'autres serveurs Matrix est désactivée.
>
> Cette précision figure aussi dans le README (annexe A) afin qu'aucune ambiguïté ne subsiste pour le jury.

> **Point de vigilance : ne pas assembler soi-même des primitives cryptographiques**
>
> Une version précédente du projet envisageait un serveur Python écrit sur mesure, avec le chiffrement côté client reposant sur @noble/curves et @noble/ciphers. Ces bibliothèques sont sérieuses, mais elles fournissent des briques (courbes, chiffrement authentifié), non un protocole complet.
>
> Choisir soi-même comment combiner ces briques (échange de clés, dérivation, rotation, gestion des groupes) revient à concevoir un protocole : c'est précisément ce que le règlement interdit, sous peine d'élimination. Le projet retient donc un protocole complet et déjà éprouvé, utilisé tel quel.

5.2 Faisabilité par dimension

Dimension	Appréciation	Justification	Niveau
Technique	Réalisable avec réserves	Briques existantes (Synapse, matrix-js-sdk, FastAPI). Point délicat : intégrer le chiffrement dans un client personnalisé et brancher la connexion TOTP	Moyen
Temporelle	Tendue	Sept jours calendaires au plus ; planification sur six jours, soit 60 heures-personne pour deux membres (section 12.1)	Moyen
Organisationnelle	Favorable avec réserves	Deux rôles clairs (infrastructure et sécurité ; interface et chiffrement) ; périmètre hiérarchisé en trois niveaux ; relecture croisée quotidienne	Moyen

Dimension	Appréciation	Justification	Niveau
Économique	Très favorable	Aucun coût de licence ; serveur de démonstration modeste (2 vCPU, 4 Go de mémoire suffisent pour 50 utilisateurs)	Élevé
Juridique et licences	Favorable	Composants open source ; licences du client vérifiées à la version figée (section 5.3)	Moyen
Sécurité et conformité	Favorable	Protocole éprouvé, aucun clair côté serveur par construction, révocation native des appareils	Élevé
Souveraineté	Très favorable	Aucune ressource externe ; installation locale complète	Élevé

5.3 Licences

Le serveur Synapse est utilisé sans modification, comme un service distinct ; il est publié sous licence AGPL-3.0. Le client s'appuie sur matrix-js-sdk et sur les bibliothèques de chiffrement de l'écosystème Matrix (vodozemac, matrix-sdk-crypto-wasm). Leur licence a été relue à la source, dans le dépôt GitHub et le registre npm, le 1er novembre 2026 : toutes sont sous Apache 2.0. **Décision : le dépôt est publié sous Apache 2.0.**

- matrix-js-sdk (version 45.0.0 à la date de vérification), vodozemac et matrix-sdk-crypto-wasm sont sous Apache 2.0, licence reconnue par l'OSI et compatible avec l'usage prévu : le dépôt entier (client et passerelle) est donc sous Apache 2.0.
- Synapse, seul composant sous AGPL-3.0, est exécuté comme un service distinct, sans modification et sans être lié au code du dépôt ; il n'impose pas sa licence au client ni à la passerelle.
- Le fichier LICENSE contient le texte de l'Apache 2.0, les versions des dépendances sont figées par les fichiers de verrouillage, et le README liste chaque composant avec sa licence.

5.4 Plans de repli

Si…	Alors…	Décision au plus tard
Le client personnalisé n'a pas un chiffrement fonctionnel à la fin du jour 3	Basculer vers un client Matrix existant (Element Web) configuré pour l'instance, et concentrer le temps restant sur la passerelle, la révocation, l'audit et l'innovation	Fin du jour 3
L'intégration de la connexion TOTP dans le flux de session retarde	Rendre le TOTP obligatoire à l'enrôlement et à la connexion via la passerelle seule, sans modifier le serveur Matrix	Fin du jour 2
Le déploiement Docker échoue sur machine vierge	Figer les versions d'images, tester sur une machine propre aux jours 4 et 6	Jour 4
L'API d'administration « connexion en tant qu'utilisateur » n'existe pas dans la version de Synapse figée	Créer l'utilisateur avec un mot de passe aléatoire fort stocké chiffré, puis appeler /_matrix/client/v3/login depuis la passerelle ; la connexion par mot de passe reste active côté Synapse, bloquée à l'extérieur par Nginx	Fin du jour 2
Le temps manque pour l'innovation	Livrer uniquement le message « Confidentiel » avec étiquette et expiration ; reporter la langue nationale et la faible connexion	Jour 5

5.5 Verdict

Le projet est **faisable** à condition de respecter trois principes : utiliser un protocole complet et ne rien développer en cryptographie ; sécuriser d'abord le socle (chiffrement, enrôlement, TOTP, révocation) avant toute fonction d'innovation ; tester le déploiement sur une machine vierge avant le dépôt.

6. Innovation

6.1 Axes d'innovation retenus

Fonction	Valeur pour l'administration burkinabè	Effort	Démontrable en direct	Bonus
Message « Confidentiel » (classification, expiration, interdiction de transfert, filigrane)	Donne une valeur de service à la confidentialité : un chef de service marque une instruction et le client applique les règles	Moyen	Oui, en moins de 60 secondes	Non
Interface en langue nationale (mooré ou dioula)	Inclusion des agents moins à l'aise en français, signal fort de souveraineté linguistique	Faible à moyen	Oui, par bascule de langue	+3 points
Mode faible connexion	Couverture irrégulière : file d'envoi différé, compression des images avant chiffrement, indicateur d'état	Moyen	Oui, en coupant le réseau	Non
Bouton d'urgence (effacement local)	Perte ou vol d'un téléphone : effacement des clés locales dès la détection de la révocation	Faible	Oui, avec la révocation	Non
Annuaire des agents par ministère et fonction	Retrouver un interlocuteur sans partager de numéro personnel	Faible	Oui	Non

6.2 Fonction principale : la classification des messages

Chaque message porte une étiquette de classification. L'étiquette fait partie du contenu chiffré : le serveur ne sait donc pas quels messages sont classifiés.

Niveau	Règles appliquées par le client	Usage type
Ordinaire	Aucune règle particulière	Échanges courants
Diffusion restreinte	Transfert interdit hors du groupe d'origine ; filigrane discret (nom de l'agent)	Notes internes, calendriers de réunion
Confidentiel	Transfert et copie bloqués dans l'interface ; filigrane dynamique (nom et heure) ; flou automatique quand la fenêtre perd le focus ; expiration automatique (durée réglable)	Instructions sensibles, données personnelles

6.3 Limites assumées

Un navigateur ne peut pas empêcher de manière fiable une capture d'écran ni la photographie d'un écran. Le projet affiche donc clairement ces limites dans la note de sécurité : les mesures sont **dissuasives et traçantes** (filigrane, flou, expiration), non absolues. L'expiration est appliquée par les clients et complétée côté serveur par une purge selon la politique de rétention ; un destinataire malveillant peut conserver une copie hors de l'application.

7. Spécifications fonctionnelles

Les priorités sont : **Obligatoire** (indispensable au socle ou à la démonstration), **Important** (valeur forte, à réaliser si le temps le permet), **Souhaitable** (bonus ou confort).

7.1 Identité et accès

ID	Exigence	Priorité	Critère d'acceptation
EF-01	L'inscription publique est désactivée ; seuls des comptes créés par un administrateur existent	Obligatoire	Toute tentative d'inscription par un tiers est rejetée (épreuve Intrus)
EF-02	Enrôlement par un administrateur : fiche agent (nom, ministère, fonction, adresse, rôle) et lien d'activation à usage unique et à durée limitée	Obligatoire	Le lien ne fonctionne qu'une fois et expire
EF-03	Mot de passe haché avec Argon2id, longueur minimale de 12 caractères	Obligatoire	Aucun mot de passe en clair en base ; refus des mots de passe trop courts
EF-04	Second facteur TOTP activé par QR code à la première connexion	Obligatoire	Connexion impossible sans code valide
EF-05	Trois rôles : Administrateur, Agent, Invité restreint (plus lecture seule pour le RSSI)	Obligatoire	Les droits respectent la matrice de la section 3.4
EF-06	Limitation des essais : verrouillage temporaire après 5 échecs	Important	Le sixième essai est refusé pendant la durée de verrouillage
EF-07	Liste des appareils actifs de l'agent et déconnexion d'un appareil	Important	L'appareil retiré perd l'accès

7.2 Messagerie

ID	Exigence	Priorité	Critère d'acceptation
EF-10	Messages directs (1-à-1) chiffrés de bout en bout	Obligatoire	Le serveur ne contient que du texte chiffré
EF-11	Messages de groupe chiffrés de bout en bout	Obligatoire	Tous les membres lisent ; un non-membre ne lit rien
EF-12	Réception en temps réel	Obligatoire	Affichage en moins de 200 ms après réception
EF-13	Historique conservé chiffré côté serveur, déchiffré sur l'appareil	Obligatoire	Un nouvel appareil autorisé retrouve l'historique selon la politique de clés retenue
EF-14	Accusé de réception ou de lecture, activable par l'expéditeur	Souhaitable	Indicateur visible uniquement si activé
EF-15	Vérification de l'empreinte d'un appareil pour confirmer l'identité de l'interlocuteur	Important	Les deux agents comparent une même empreinte

7.3 Fichiers

ID	Exigence	Priorité	Critère d'acceptation
EF-20	Envoi de pièces jointes (images, PDF, documents) chiffrées avant envoi	Obligatoire	Le fichier stocké sur le serveur est illisible

ID	Exigence	Priorité	Critère d'acceptation
EF-21	Taille maximale de 10 Mo, configurable	Obligatoire	Un fichier plus gros est refusé avec un message clair
EF-22	Types de fichiers autorisés par liste blanche	Important	Un type interdit est refusé
EF-23	Aperçu des images et des PDF après déchiffrement sur l'appareil	Important	Aucun envoi du fichier en clair vers un service externe

7.4 Groupes

ID	Exigence	Priorité	Critère d'acceptation
EF-30	Création d'un groupe par un agent ou un administrateur	Obligatoire	Le groupe apparaît chez les membres invités
EF-31	Ajout et retrait de membres	Obligatoire	Un membre retiré ne reçoit plus les nouveaux messages
EF-32	Invitation d'un invité restreint limitée à une conversation	Important	L'invité ne voit aucune autre conversation
EF-33	Un compte non enrôlé ne peut ni être invité ni rejoindre un groupe	Obligatoire	Épreuve Intrus réussie

7.5 Révocation

ID	Exigence	Priorité	Critère d'acceptation
EF-40	Révocation d'un agent depuis sa fiche, avec confirmation	Obligatoire	Statut « révoqué » immédiatement visible
EF-41	Invalidation des sessions et suppression des appareils sur tous les terminaux	Obligatoire	Toute requête de l'agent est refusée en quelques secondes
EF-42	Retrait des salons et renouvellement des clés de groupe	Obligatoire	L'agent révoqué ne peut lire aucun nouveau message du groupe
EF-43	Inscription de la révocation au journal d'audit	Obligatoire	Entrée datée avec l'auteur et la cible
EF-44	Effacement des clés locales à la détection de la révocation (bouton d'urgence)	Souhaitable	Le client vide son stockage local à la première réponse refusée

7.6 Administration

ID	Exigence	Priorité	Critère d'acceptation
EF-50	Tableau de bord : nombre d'agents actifs, en attente et révoqués, répartition par rôle	Important	Les chiffres correspondent à la base
EF-51	Journal d'audit daté : enrôlement, révocation, changement de rôle, échecs de connexion	Obligatoire	Aucune modification possible depuis l'interface
EF-52	Configuration : rétention, taille maximale des fichiers, niveaux de classification, durée d'expiration par défaut	Important	Les changements s'appliquent sans redémarrage complet

ID	Exigence	Priorité	Critère d'acceptation
EF-53	Export du journal d'audit au format CSV	Souhaitable	Fichier téléchargeable par l'administrateur et le RSSI

7.7 Innovation

ID	Exigence	Priorité	Critère d'acceptation
EF-60	Choix d'un niveau de classification à l'envoi (Ordinaire, Diffusion restreinte, Confidentiel), inclus dans le contenu chiffré	Obligatoire	Le serveur n'a aucun champ révélant le niveau
EF-61	Règles du niveau Confidentiel : transfert bloqué, filigrane, flou à la perte de focus, expiration	Important	Démonstration en moins de 60 secondes
EF-62	Interface en langue nationale (mooré ou dioula) pour les pages de connexion, liste et conversation	Souhaitable	Bascule de langue sans rechargement
EF-63	Mode faible connexion : file d'envoi différé, compression des images, indicateur d'état	Souhaitable	Un message écrit hors ligne part au retour du réseau
EF-64	Annuaire des agents par ministère et fonction	Souhaitable	Recherche par nom, ministère ou fonction

8. Exigences non fonctionnelles

ID	Catégorie	Exigence	Vérification
ENF-01	Sécurité	Aucun message ni fichier en clair côté serveur (éliminatoire)	Requête sur la base et capture du trafic
ENF-02	Sécurité	Aucune cryptographie développée par l'équipe (éliminatoire)	Revue de code : seuls des appels à la bibliothèque Matrix
ENF-03	Sécurité	Transport protégé par TLS 1.2 ou supérieur (certificat de démonstration)	Inspection du proxy
ENF-04	Sécurité	Clés privées jamais transmises au serveur	Revue du trafic et du code client
ENF-05	Sécurité	Secrets TOTP chiffrés au repos avec une clé de service ; mots de passe Argon2id	Inspection de la base de la passerelle
ENF-06	Sécurité	Politique de contenu stricte (CSP), pas de HTML brut injecté dans les messages	En-têtes HTTP et revue du client
ENF-07	Performance	Affichage d'un message reçu en moins de 200 ms ; 50 utilisateurs simultanés ; fichiers jusqu'à 10 Mo	Essai de charge léger
ENF-08	Disponibilité	Redémarrage automatique des conteneurs ; procédure de sauvegarde documentée	Arrêt et relance d'un conteneur
ENF-09	Utilisabilité	Interface adaptée aux téléphones (largeur 360 px) et aux ordinateurs ; envoi d'un message en trois actions au plus	Essai sur téléphone
ENF-10	Portabilité	Navigateurs récents (Chrome, Firefox, Edge)	Essai croisé
ENF-11	Déploiement	Une seule commande : docker compose up -d, avec comptes fictifs pré-créés	Essai sur machine vierge

ID	Catégorie	Exigence	Vérification
ENF-12	Souveraineté	Aucune ressource externe chargée (polices, CDN, mesures d'audience)	Navigateur hors ligne, onglet Réseau
ENF-13	Maintenabilité	Code documenté, tests automatisés des fonctions de sécurité, commits progressifs	Historique Git et rapport de tests
ENF-14	Conformité	Fichier LICENSE, composants cités avec licence et lien, données fictives uniquement	Liste de contrôle (section 14)
ENF-15	Portabilité	Application web progressive installable sur ordinateur et téléphone (manifeste, service worker, HTTPS) ; ajout à l'écran d'accueil depuis Safari sur iPhone	Contrôle d'installabilité dans les outils du navigateur ; essai sur téléphone
ENF-16	Sécurité	Dépendances figées et auditées ; aucune vulnérabilité critique connue au dépôt	Rapports pip-audit et npm audit
ENF-17	Sécurité	Journal d'audit chaîné par empreintes SHA-256 : toute modification ou suppression d'une entrée est détectée	Script de vérification de la chaîne
ENF-18	Sécurité	Version et empreinte SHA-256 du client affichées et comparables à la référence publiée ; tout écart est signalé	Comparaison avec la référence publiée
ENF-19	Sécurité	Tests de sécurité automatisés exécutés avant toute mise en service, dont le blocage externe de /login et de /_synapse/admin ; un échec bloque le déploiement	Rapport de tests ; échec volontaire
ENF-20	Sécurité	Toute modification d'un paramètre de sécurité est inscrite au journal d'audit avec son auteur et déclenche une alerte	Changement d'un paramètre puis lecture du journal

9. Architecture technique

9.1 Vue d'ensemble

L'architecture est de type « zéro confiance envers le serveur » : tout le chiffrement et le déchiffrement se font dans le navigateur de l'agent ; le serveur n'achemine et ne stocke que du texte chiffré. Un proxy inverse expose deux services : la passerelle d'identité (enrôlement, authentification forte, rôles, audit, révocation) et le serveur Matrix (messagerie).

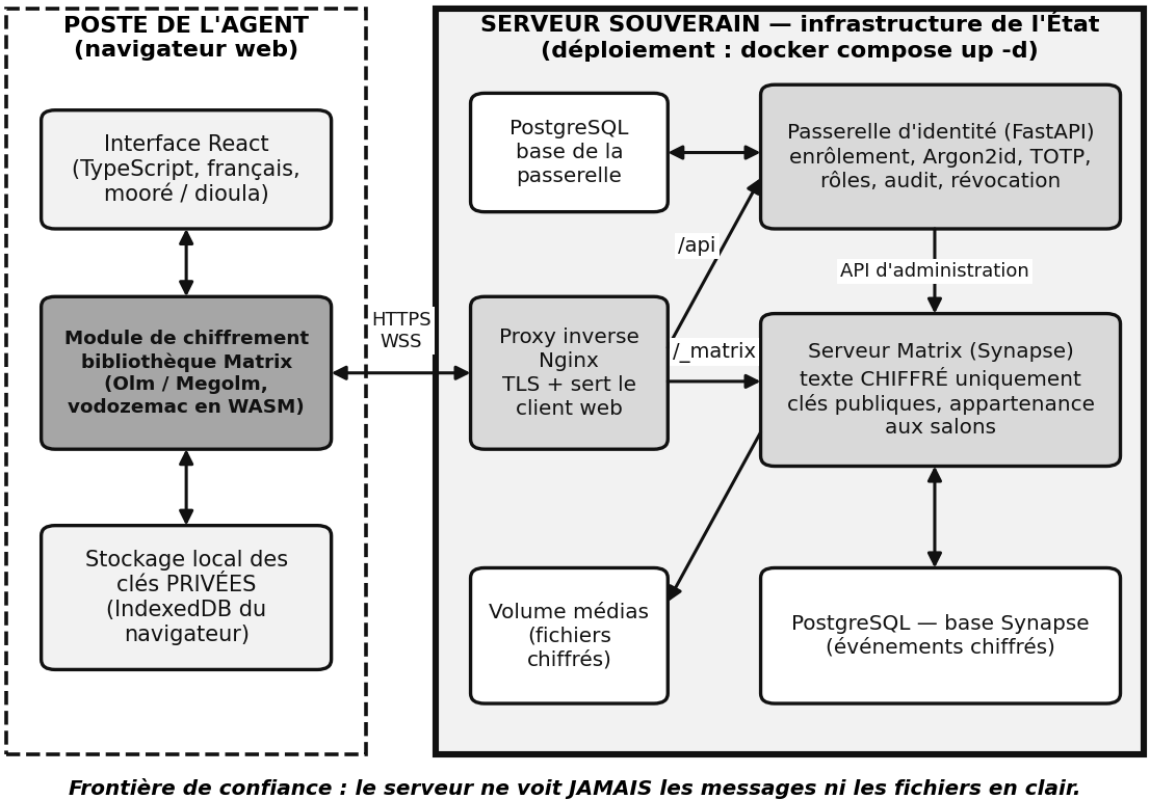


Figure 2 – Architecture technique de SovereignMsg

9.2 Composants et licences

Couche	Composant	Rôle	Licence*	Lien
Client	React + TypeScript (Vite)	Interface web	MIT	https://react.dev
Client	matrix-js-sdk	Protocole Matrix côté client	Apache 2.0	https://github.com/matrix-org/matrix-js-sdk
Client	matrix-sdk-crypto-wasm / vodozemac	Chiffrement Olm / Megolm	Apache 2.0	https://github.com/matrix-org/vodozemac
Client	i18next	Traduction (français, mooré, dioula)	MIT	https://www.i18next.com
Passerelle	Python 3.12 + FastAPI	API d'enrôlement, d'authentification et d'administration	PSF / MIT	https://fastapi.tiangolo.com
Passerelle	argon2-cffi	Hachage des mots de passe (Argon2id)	MIT	https://github.com/hynek/argon2-cffi
Passerelle	pyotp	Codes TOTP	MIT	https://github.com/pyauth/pyotp
Passerelle	SQLAlchemy	Accès à la base	MIT	https://www.sqlalchemy.org
Serveur de messagerie	Synapse	Serveur Matrix (non modifié)	AGPL-3.0	https://github.com/element-hq/synapse
Données	PostgreSQL	Bases de la passerelle et de Synapse	Licence PostgreSQL	https://www.postgresql.org

Couche	Composant	Rôle	Licence*	Lien
Accès	Nginx	Proxy inverse, TLS, service du client	BSD-2-Clause	https://nginx.org
Déploiement	Docker et Docker Compose	Conteneurs et orchestration	Apache 2.0	https://www.docker.com
Qualité	pytest, Vitest	Tests automatisés	MIT	https://pytest.org

** Licences de matrix-js-sdk, vodozemac et matrix-sdk-crypto-wasm vérifiées le 1er novembre 2026 dans les dépôts d'origine ; les autres sont relues à la version figée (section 5.3).*

9.3 Parcours d'un message chiffré

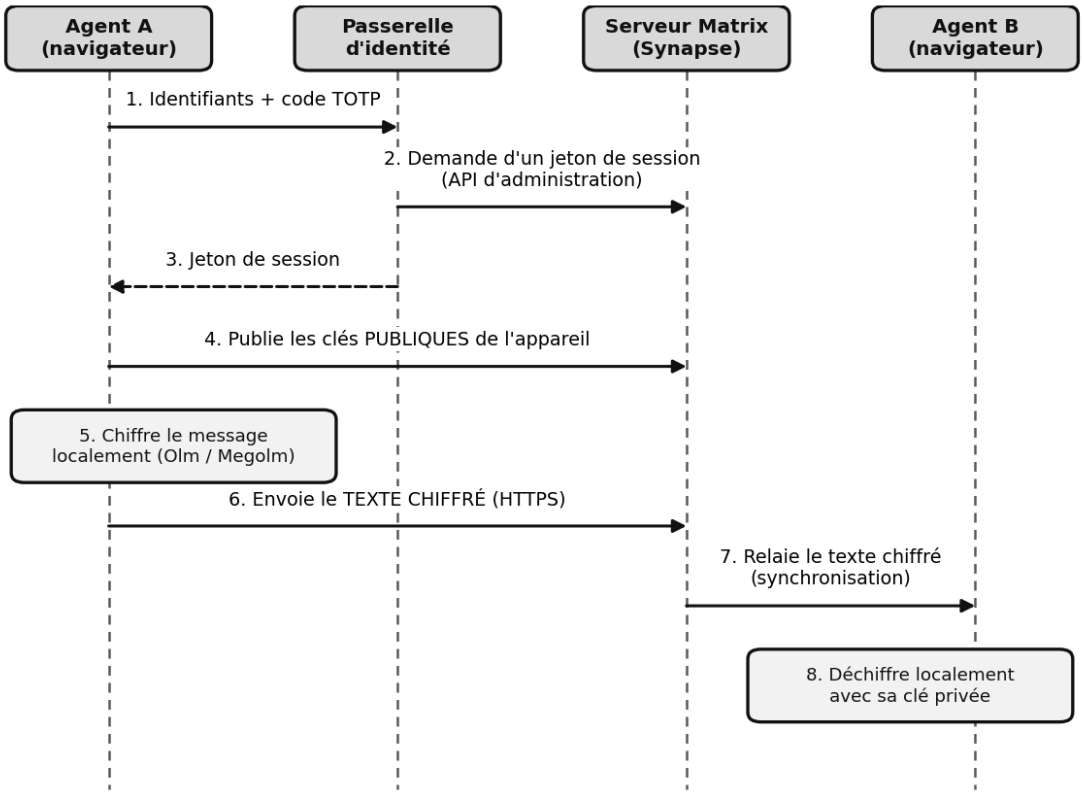


Figure 3 – Connexion et envoi d'un message chiffré entre deux agents

La passerelle contrôle l'identité (mot de passe Argon2id puis code TOTP) avant d'obtenir de Synapse, par son API d'administration (réseau interne uniquement), un jeton d'accès Matrix pour l'agent ; elle renvoie au client ce jeton et son propre jeton de session. Le client publie ensuite uniquement les clés publiques de l'appareil. Les clés privées ne quittent jamais le navigateur.

9.4 Parcours de révocation

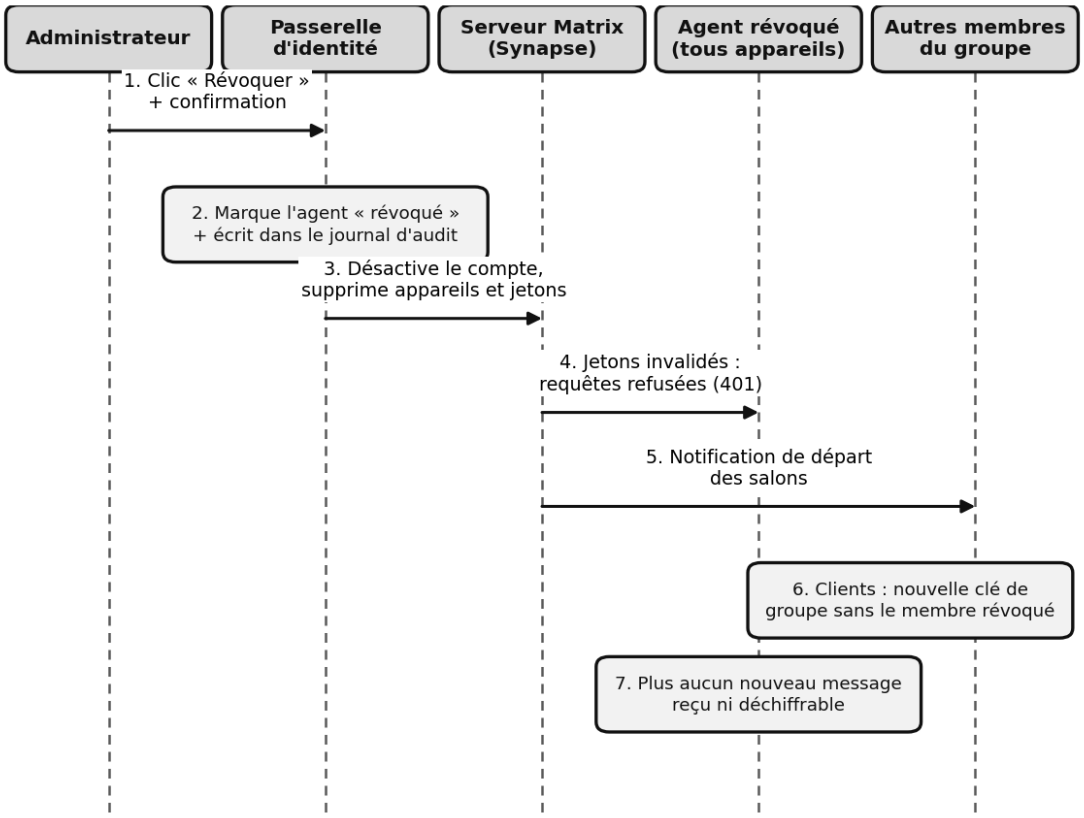


Figure 4 – Révocation d'un agent sur tous ses appareils

La révocation agit à trois niveaux : le compte est désactivé et les appareils supprimés (accès coupé à la requête suivante, soit quelques secondes) ; l'agent est retiré des salons ; les clients des autres membres renouvellent la clé de groupe, de sorte que les nouveaux messages ne sont plus déchiffrables par l'agent révoqué. Les noms exacts des appels de l'API d'administration sont à vérifier dans la documentation de la version de Synapse retenue.

> **Limite connue de la révocation**
> Les messages déjà reçus et déchiffrés sur un appareil avant la révocation restent lisibles sur cet appareil tant que le client n'a pas effacé ses données locales. Le bouton d'urgence (EF-44) réduit ce risque sans le supprimer si l'appareil reste hors ligne.

9.5 Modèle de données de la passerelle

Table	Champs principaux	Sensibilité
agents	id, identifiant Matrix, nom, ministère, fonction, rôle, statut (en attente, actif, révoqué), mot de passe haché (Argon2id), secret TOTP chiffré, dates de création et de révocation	Élevée : secrets chiffrés ou hachés
jetons_activation	id, agent, empreinte du jeton, expiration, utilisé	Moyenne
journal_audit	id, date, auteur, action, cible, détail, empreinte de l'entrée précédente, empreinte de l'entrée (chaînage)	Moyenne : écrit uniquement par la passerelle
niveaux_classification	id, libellé, transfert interdit, filigrane, expiration en secondes	Faible

Table	Champs principaux	Sensibilité
parametres	clé, valeur (rétention, taille maximale de fichier, durée de verrouillage)	Faible

Les figures 5 à 7 complètent le modèle de données. La figure 5 présente les classes du domaine de la passerelle, la figure 6 les services de la passerelle et les classes du client, la figure 7 le cycle de vie d'un compte agent. Les messages en clair n'existent que dans le client (classe MessageClair) : aucune classe du serveur ne porte de contenu.

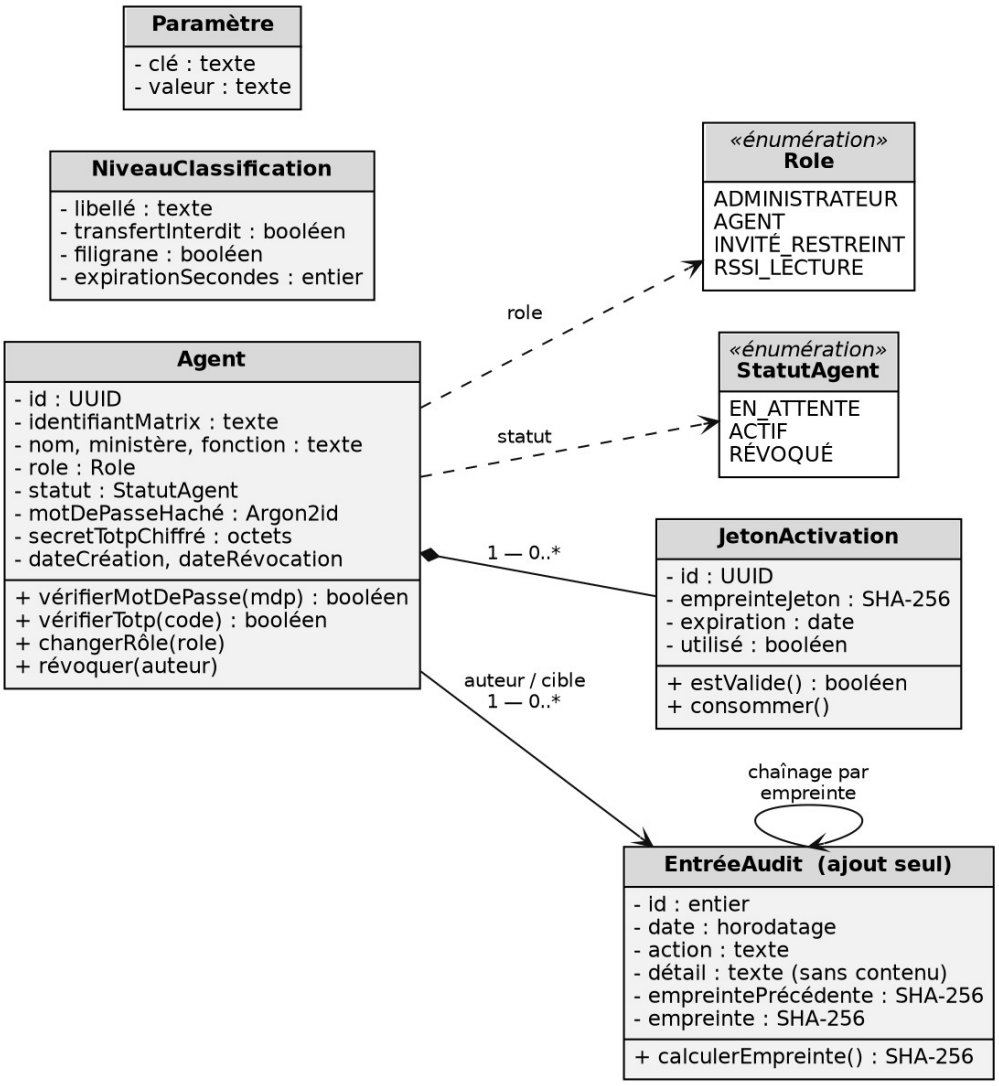


Figure 5 – Diagramme de classes : modèle du domaine de la passerelle

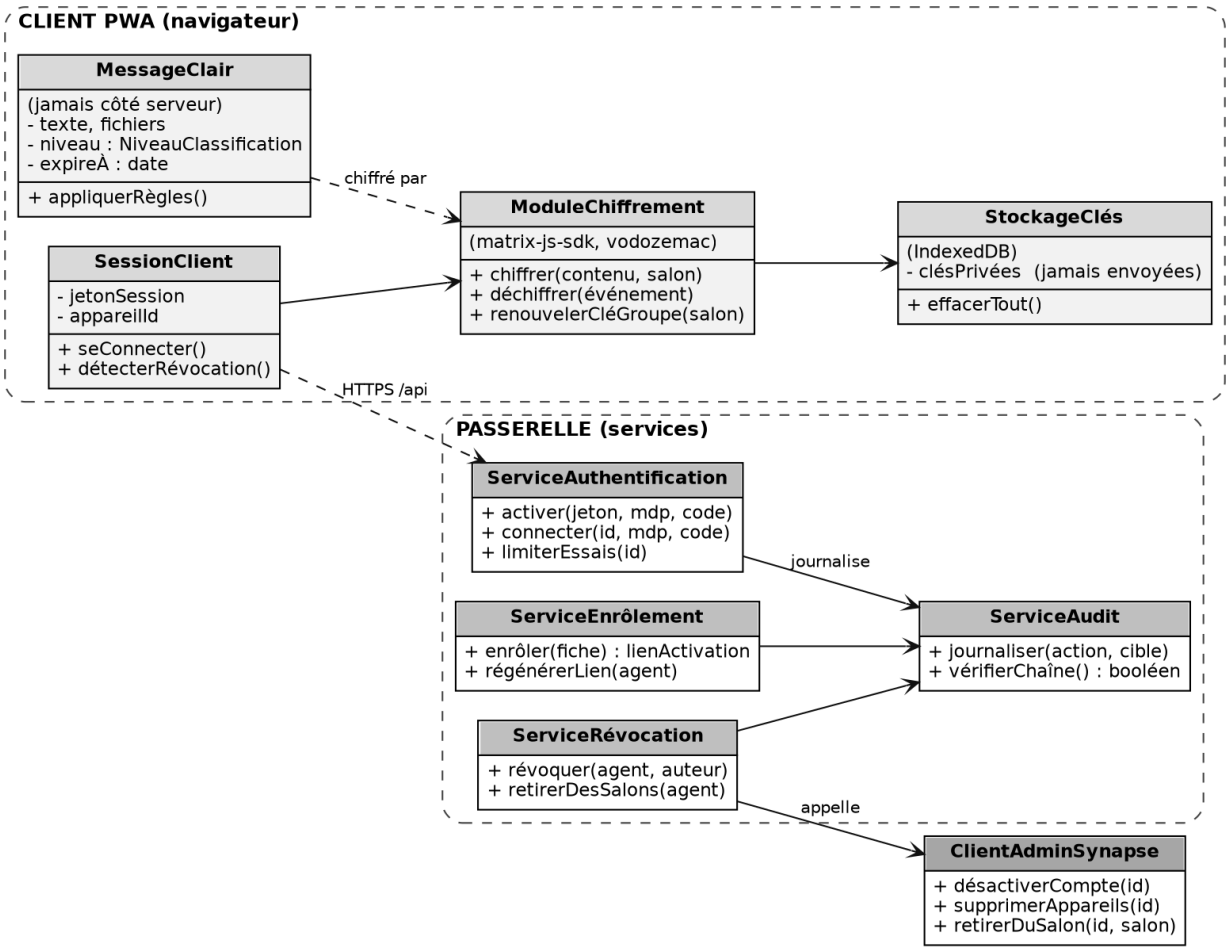


Figure 6 – Diagramme de classes : services de la passerelle et client PWA

Le statut d'un compte suit un cycle de vie simple. Un agent naît « en attente » à l'enrôlement, devient « actif » après activation (mot de passe et TOTP), peut être verrouillé temporairement après cinq échecs, et finit « révoqué » : cet état est définitif, il n'existe pas de réactivation, un nouvel enrôlement crée un nouveau compte.

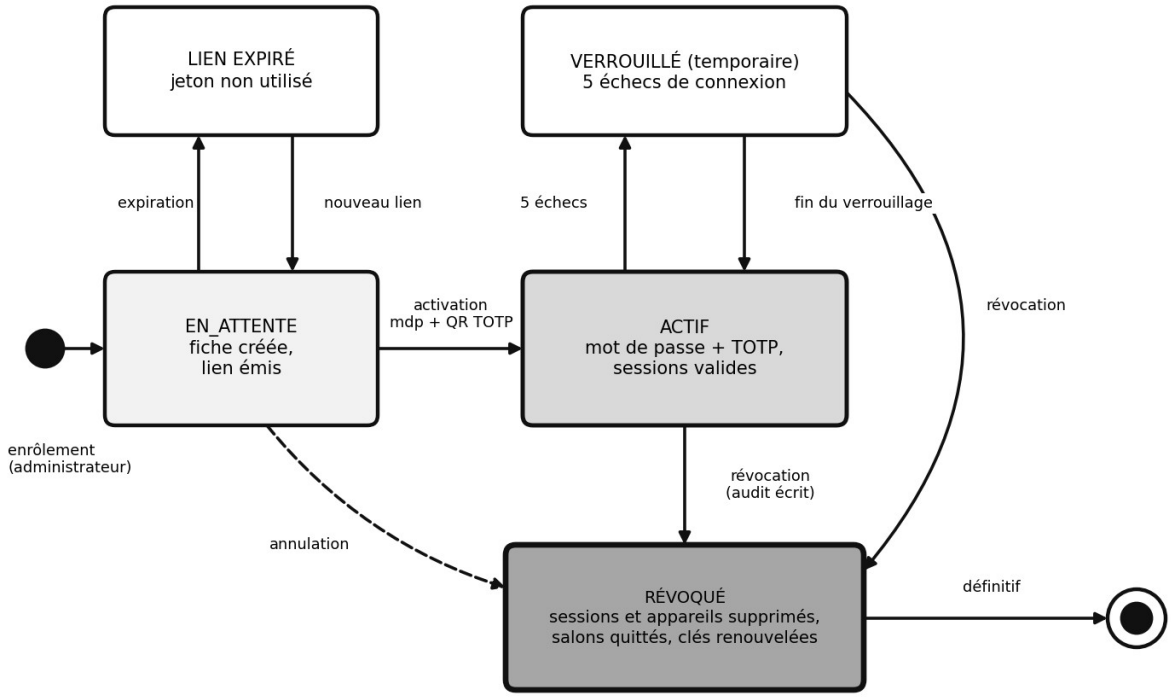


Figure 7 – Diagramme d'états d'un compte agent

9.6 Interfaces de la passerelle

Route	Accès	Fonction
POST /api/auth/activation	Jeton d'activation	Définit le mot de passe et enrôle le TOTP
POST /api/auth/login	Public (agents enrôlés)	Vérifie mot de passe et TOTP, appelle l'API d'administration de Synapse, renvoie le jeton de session de la passerelle et l'access_token Matrix
GET /api/me	Agent	Profil et rôle de l'agent connecté
GET /api/annuaire	Agent	Recherche d'agents par nom, ministère, fonction
POST /api/admin/agents	Administrateur	Enrôle un agent et génère le lien d'activation
GET /api/admin/agents	Administrateur	Liste et statuts des agents
PATCH /api/admin/agents/{id}/role	Administrateur	Change le rôle d'un agent
POST /api/admin/agents/{id}/revoquer	Administrateur	Révoque l'agent et coupe ses accès
GET /api/admin/audit	Administrateur, RSSI	Journal d'audit (lecture)
GET, PUT /api/admin/parametres	Administrateur (RSSI en lecture)	Lecture et modification de la configuration

Appel à l'API d'administration de Synapse. Après vérification du mot de passe et du code TOTP, la route /api/auth/login appelle l'API d'administration de Synapse au moyen d'un client HTTP (httpx) : elle crée l'utilisateur Matrix s'il n'existe pas, puis obtient un access_token pour cet utilisateur, avec une durée de validité limitée. Elle renvoie deux jetons au client : le jeton de session de la passerelle (court, signé, utilisé pour les routes /api) et l'access_token Matrix avec l'identifiant de l'utilisateur ; le client interroge ensuite Synapse pour obtenir l'identifiant de son appareil et initialiser le chiffrement.

Frontière du proxy. Les routes /_synapse/admin, /_matrix/client/*/login et /_matrix/client/*/register (toutes versions de chemin) sont bloquées par Nginx pour les requêtes venant de l'extérieur ; seule la passerelle, sur le réseau Docker interne, y accède. La connexion par mot de passe reste active dans Synapse, car le compte administrateur dédié de la passerelle s'y connecte par mot de passe ; les comptes des agents sont créés sans mot de passe utilisable. La sécurité de cette frontière repose donc aussi sur la règle du proxy (défense en profondeur) : elle est testée automatiquement avant chaque mise en service (ENF-19, section 9.11). Les noms exacts des appels sont à confirmer dans la documentation de la version de Synapse figée.

9.7 Déploiement

Service	Source	Rôle	Exposition
proxy	Image officielle Nginx	TLS, client web, routage /api et /_matrix ; /login et /_synapse/admin bloqués depuis l'extérieur	Port 443 (seul port ouvert)
gateway	Construit depuis ./gateway (Python, FastAPI)	Identité, rôles, audit, révocation	Réseau interne
synapse	Image officielle Synapse	Serveur Matrix	Réseau interne
db	Image officielle PostgreSQL	Deux bases : passerelle et Synapse	Réseau interne
init	Script d'amorçage (tâche unique)	Génère les secrets de démonstration et crée l'administrateur et les comptes fictifs	Aucune

Commande d'installation :

```
docker compose up -d
```

Arborescence prévue du dépôt :

```
sovereignmsg/
├── LICENSE
├── README.md              (français, 2 pages au maximum)
├── docker-compose.yml
├── gateway/               (FastAPI : enrôlement, TOTP, rôles, audit, révocation)
│   ├── app/
│   └── tests/             (tests des fonctions de sécurité)
├── client/                (React + TypeScript, matrix-js-sdk)
│   ├── src/pages/         (P01 à P18)
│   ├── src/locales/       (fr, mooré, dioula)
│   └── tests/
├── deploy/                (configuration Nginx, Synapse, amorçage)
└── docs/                  (note de pré-projet, note de sécurité)
```

9.8 Métadonnées visibles par le serveur et mesures de réduction

Le serveur ne lit pas les messages, mais il voit nécessairement certaines informations. Le tableau les liste honnêtement, comme l'exige le règlement.

Information visible	Pourquoi	Mesure de réduction	Reste exposé ?
Identité des comptes (nom, ministère)	Annuaire et contrôle d'accès	Identifiants Matrix pseudonymisés ; détails stockés uniquement dans la passerelle	Oui, par l'administrateur

Information visible	Pourquoi	Mesure de réduction	Reste exposé ?
Appartenance aux conversations (qui est avec qui)	Routage des messages	Aucune réduction possible sans changer de modèle	Oui : limite connue
Date et heure des messages	Acheminement et ordre des messages	Aucune réduction possible	Oui : limite connue
Taille approximative des messages et fichiers	Stockage et transport	Limite de taille ; remplissage non prévu	Oui : limite connue
Adresses IP des appareils	Connexion réseau	Journaux d'accès du proxy sans adresses ; durée de conservation des adresses réduite dans la configuration de Synapse	Réduit
Présence et frappe en cours	Fonctions de confort	Désactivées dans la configuration	Non
Contenu, noms de fichiers, niveau de classification	Sans objet	Dans le contenu chiffré	Non
Noms, descriptions et membres des groupes	Les événements d'état des salons ne sont pas chiffrés par défaut	Noms de groupes neutres, aucune donnée sensible dans les noms ou descriptions	Oui : limite connue
Clés publiques des appareils	Établissement des sessions chiffrées	Vérification d'empreinte par les agents	Oui : par nature publiques

9.9 Modèle de menaces

Menace	Scénario	Protection	Limite résiduelle
Écoute du réseau	Interception du trafic	TLS + chiffrement de bout en bout	Métadonnées de trafic
Serveur compromis ou administrateur malveillant	Lecture de la base ou des fichiers	Le serveur ne détient que du texte chiffré	Métadonnées ; ajout d'un appareil malveillant : vérification des empreintes
Vol de compte	Mot de passe deviné ou volé	Argon2id, TOTP, limitation des essais	Vol simultané du téléphone TOTP
Appareil perdu ou volé	Accès aux conversations	Révocation, effacement local, rotation des clés	Messages déjà déchiffrés sur l'appareil hors ligne
Intrus non enrôlé	Inscription ou invitation	Inscription désactivée, connexion directe à Synapse bloquée par Nginx, statut vérifié à chaque session	Aucune connue pour le prototype
Fuite par un destinataire	Capture d'écran, copie	Classification, filigrane, flou, expiration	Photographie de l'écran : non évitable
Injection dans le client	Script malveillant dans un message	CSP stricte, échappement systématique, pas de HTML brut	Faille inconnue d'une dépendance
Falsification de l'audit	Effacement de traces	Écriture réservée à la passerelle ; chaînage par empreintes SHA-256 (toute modification est détectée) ; copie périodique en écriture seule	Suppression des dernières entrées avant la copie ; administrateur de base de données

Menace	Scénario	Protection	Limite résiduelle
Chaîne d'approvisionnement	Dépendance malveillante	Versions figées et verrouillées, peu de dépendances	Vulnérabilité non encore connue
Modification malveillante du serveur ou du client servi	Un attaquant maître du serveur modifie le client web distribué aux agents	Client servi en fichiers statiques versionnés, CSP stricte, empreinte SHA-256 publiée et affichée, mise à jour du client validée avant publication	Dans un navigateur, un serveur entièrement compromis peut servir un client altéré avant détection : l'empreinte réduit le risque sans l'éliminer
Contournement de la passerelle	Appel direct à /_matrix/client/v3/login, à /register ou à l'API d'administration depuis Internet	Routes bloquées par Nginx pour toutes les versions de chemin ; comptes des agents sans mot de passe utilisable ; port client de Synapse non publié ; règle testée automatiquement avant chaque mise en service (ENF-19)	Une erreur dans la règle du proxy rouvrirait la route : la sécurité repose en partie sur cette règle, d'où le test automatisé
Déni de service	Saturation du serveur	Limitation de débit au proxy	Hors périmètre du prototype

9.10 Front-office et back-office

SovereignMsg sépare deux espaces servis par la même application web progressive. Le **front-office** est tout ce que l'agent voit et utilise au quotidien : connexion, conversations, groupes, fichiers, classification des messages, vérification des appareils. Le **back-office** regroupe la console d'administration (interface réservée aux rôles Administrateur et RSSI) et les services de fond qui tournent sur le serveur de l'État : passerelle d'identité, serveur Matrix, bases de données, proxy. Un seul code source est livré ; l'espace affiché dépend du rôle, mais chaque action est autorisée ou refusée par la passerelle, jamais par l'interface seule.

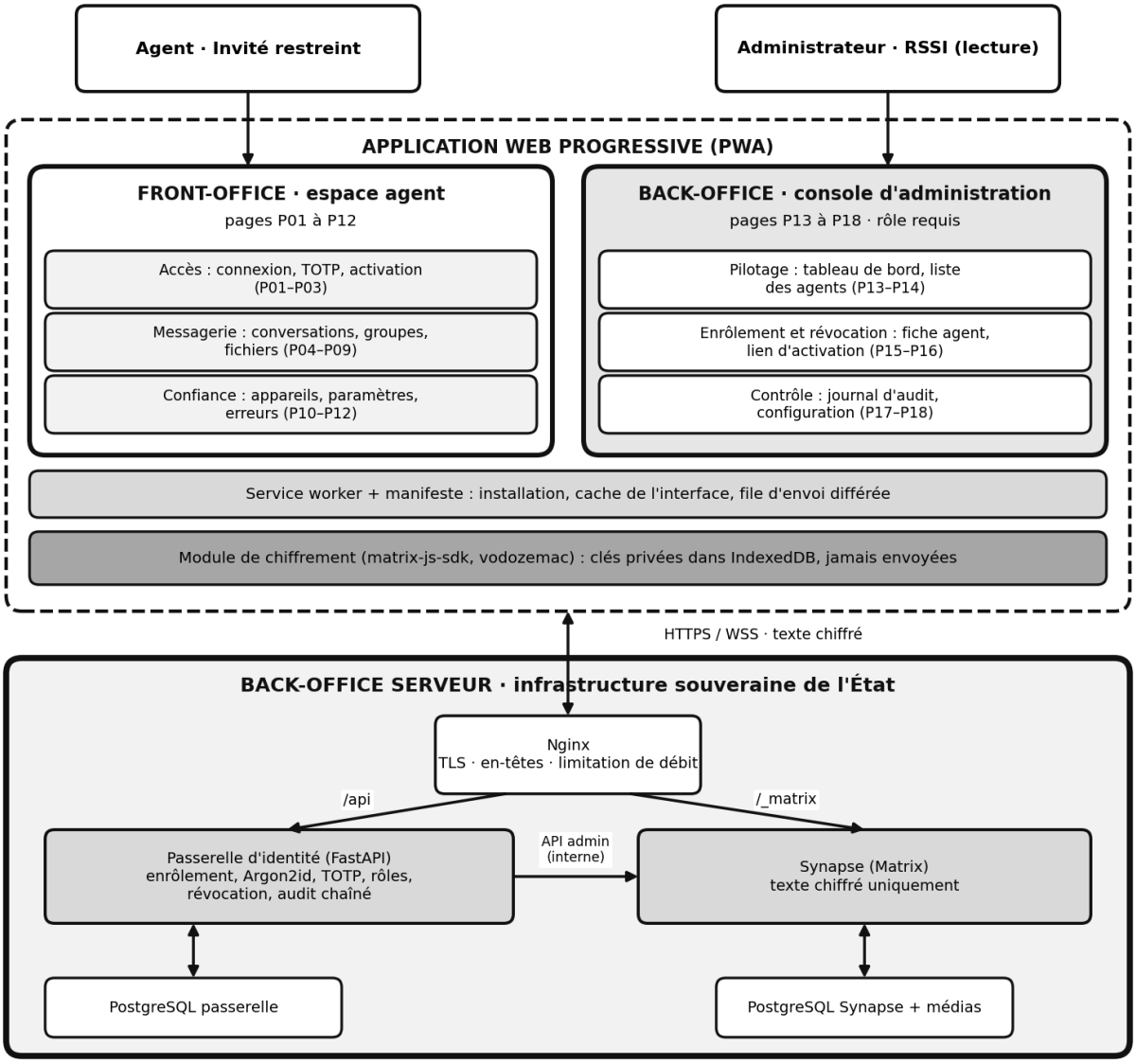


Figure 8 – Front-office et back-office de SovereignMsg

Critère	Front-office (espace agent)	Back-office (administration et services)
Utilisateurs	Agent, invité restreint	Administrateur, RSSI (lecture seule) ; côté serveur, les services de fond
Objectif	Échanger vite et de façon confidentielle	Contrôler qui entre, qui reste, et garder la trace de ce qui s'est passé
Pages	P01 à P12 : accès, messagerie, confiance	P13 à P18 : pilotage, enrôlement, révocation, audit, configuration
Fonctions principales	Connexion avec TOTP, messages directs et de groupe, fichiers chiffrés, classification (EF-10 à EF-23, EF-60 à EF-64)	Enrôlement, rôles, révocation, tableau de bord, journal d'audit, configuration (EF-02, EF-40 à EF-53)
Données manipulées	Contenus chiffrés de bout en bout ; clés privées de l'appareil	Fiches des agents, statuts, journal d'audit ; jamais le contenu d'un message
Composants	Application React, module de chiffrement, service worker	Console d'administration, passerelle FastAPI, Synapse, PostgreSQL, Nginx

Critère	Front-office (espace agent)	Back-office (administration et services)
Contrôle d'accès	Session valide, compte actif, appareil non révoqué	Rôle Administrateur ou RSSI vérifié par la passerelle à chaque requête ; TOTP obligatoire
Réalisation (section 12)	Membre 2, jours 2 à 4	Membre 1 pour les services (jours 1 à 5) ; Membre 2 pour la console (jour 5)

Frontière entre les deux espaces. Le back-office ne voit jamais le contenu des messages : il gère des identités, des rôles et des traces. Le front-office n'a accès à aucune route d'administration : les routes /api/admin exigent le rôle Administrateur ou RSSI (section 9.6), et un agent qui les appelle reçoit un refus consigné dans le journal d'audit.

9.11 Sécurité sur tout le cycle de vie

La sécurité n'est pas ajoutée à la fin : elle est posée avant la conception, vérifiée pendant la réalisation, contrôlée au déploiement, surveillée en production et maintenue après l'hébergement. La conception vise une propriété précise : **la confidentialité du contenu ne dépend ni de la bonne foi du serveur ni de l'état de sa configuration**, parce que les clés privées restent sur les appareils. Ce qui peut être modifié ou compromis côté serveur (disponibilité, métadonnées, client servi) est surveillé, tracé et retesté.

Le tableau ci-dessous précise la portée de chaque mesure : « Prototype » signifie réalisée et démontrable pendant les six jours ; « Production » signifie prévue pour l'exploitation réelle et décrite dans le dossier, sans être développée pendant le sprint.

Étape	Mesure	Portée	Preuve ou vérification
0. Avant la conception	Analyse de risques, modèle de menaces (section 9.9) et classification des données : le contenu est secret, les métadonnées sont sensibles	Prototype	Sections 9.8 et 9.9
0. Avant la conception	Protocole complet et éprouvé (Matrix : Olm, Megolm) ; aucune cryptographie développée par l'équipe	Prototype	Section 5.1 ; ENF-02
0. Avant la conception	Exigences de sécurité numérotées et cadre légal (loi 001-2021/AN, loi sur la sécurité des systèmes d'information)	Prototype	Sections 1.6 et 8
1. Conception	Frontière de confiance : le navigateur chiffre, le serveur n'achemine que du texte chiffré ; passerelle et Synapse séparés, deux bases ; seul le port 443 exposé	Prototype	Figure 2 ; section 9.7
1. Conception	Moindre privilège et échec fermé : statut de l'agent vérifié à chaque session ; API d'administration et port client de Synapse jamais publiés (réseau interne seulement)	Prototype	Épreuves Intrus et Révocation
1. Conception	Minimisation des données et des métadonnées ; journal d'audit sans contenu de message	Prototype	Section 9.8
1. Conception	Revue de conception croisée entre les deux membres avant le codage	Prototype	Compte rendu daté
2. Réalisation	Versions figées (fichiers de verrouillage), peu de dépendances, audit des dépendances (pip-audit, npm audit)	Prototype	ENF-16 ; rapport au dépôt

Étape	Mesure	Portée	Preuve ou vérification
2. Réalisation	Analyse statique (Bandit, ESLint) et recherche de secrets avant chaque commit ; aucun secret dans Git	Prototype	Sortie des outils
2. Réalisation	Tests automatisés, dont des tests négatifs : intrus rejeté, mauvais code TOTP, droits insuffisants, lien d'activation rejoué, accès après révocation	Prototype	ENF-13 ; rapport de tests
2. Réalisation	Relecture croisée de toute fonction d'authentification et de chiffrement ; contrôle « aucun clair en base » avant chaque commit	Prototype	Annexe B.3, requête 3 = 0
3. Déploiement	Images à versions figées, conteneurs sans privilèges, secrets injectés à l'exécution et jamais dans l'image	Prototype	Fichier Compose
3. Déploiement	TLS 1.2 ou plus, en-têtes de sécurité (CSP stricte, HSTS, X-Content-Type-Options), limitation de débit, inscription et fédération désactivées ; routes /_synapse/admin, /_matrix/client/*/login et /register bloquées depuis l'extérieur par Nginx. La sécurité de la passerelle repose aussi sur cette règle (défense en profondeur) : elle est testée automatiquement avant chaque mise en service	Prototype	ENF-03, ENF-06, ENF-19 ; annexe B.1
3. Déploiement	Empreinte SHA-256 du client publiée avec la version ; version et empreinte affichées dans l'application	Prototype	ENF-18
3. Déploiement	Essai complet sur machine vierge ; mise en service refusée si un test de sécurité échoue	Prototype	ENF-11, ENF-19
4. Production	Journal d'audit chaîné par empreintes ; entrées d'alerte sur échecs répétés, connexion d'un compte révoqué et modification de la configuration	Prototype ; alerte en production	ENF-17, ENF-20
4. Production	Supervision des conteneurs, redémarrage automatique, sauvegardes chiffrées avec essai de restauration	Production	ENF-08
4. Production	Rotation des secrets et des jetons ; correctifs de sécurité testés avant déploiement, avec retour arrière possible	Production	Procédure d'exploitation
4. Production	Séparation des rôles : le RSSI lit le journal sans pouvoir agir ; un paramètre de sécurité critique est validé par un second administrateur	Production	Matrice des droits (3.4)
5. Après l'hébergement	Hébergement sur serveur de l'État : disque chiffré, accès physique et administrateur restreints, journal des accès	Production	Procédure d'hébergement
5. Après l'hébergement	Contrôle d'intégrité planifié : empreintes de la configuration et du client servi comparées à la référence publiée ; alerte en cas d'écart	Production	ENF-18
5. Après l'hébergement	Tout changement (code, image, paramètre) rejoue les tests de sécurité avant mise en service ; la preuve « aucun clair en base » est rejouée chaque jour	Production	ENF-19
5. Après l'hébergement	Changement d'hébergeur ou restauration : les clés privées restent sur les appareils, le contenu reste illisible pour le nouvel hébergeur	Production	Principe du chiffrement de bout en bout

Étape	Mesure	Portée	Preuve ou vérification
5. Après l'hébergement	Fin de vie : révocation de tous les comptes, effacement sécurisé des sauvegardes, destruction des secrets de service	Production	Procédure de sortie

La figure 9 résume l'enchaînement des six étapes et le rôle de la surveillance continue.

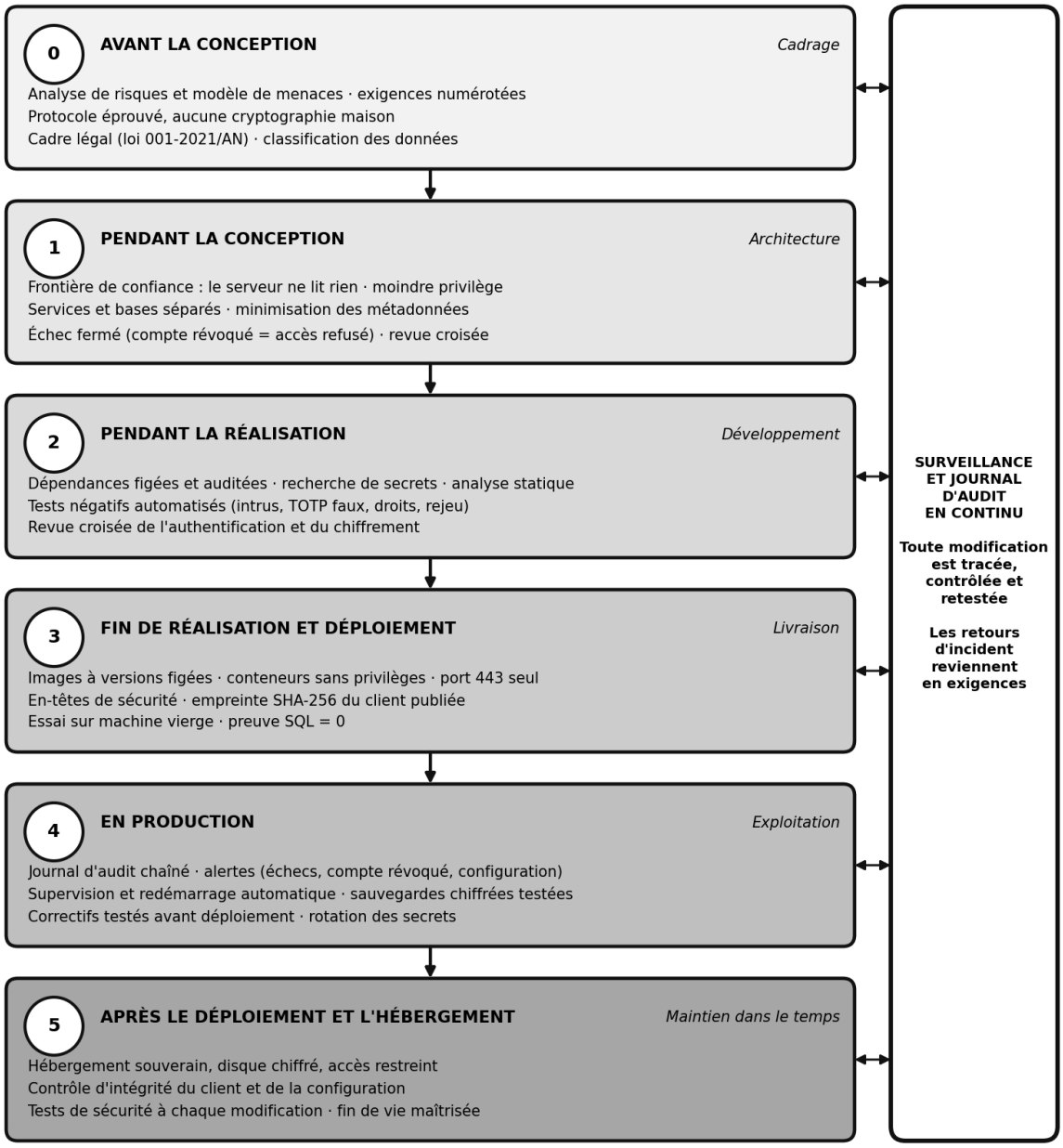


Figure 9 – La sécurité à chaque étape du cycle de vie de SovereignMsg

Ce qui reste garanti quand quelque chose est modifié. Le tableau suivant répond à la question du RSSI : que se passe-t-il si le serveur, la base, le journal ou le client sont modifiés ?

Modification	Ce qui reste garanti	Ce qui peut être touché	Détection et réaction
Configuration du serveur ou de Synapse modifiée, par erreur ou par malveillance	Le contenu des messages reste illisible : les clés sont sur les appareils	Métadonnées, disponibilité	Entrée d'audit, écart d'empreinte de configuration, tests de sécurité rejoués avant remise en service
Base de données lue ou copiée	Aucun clair (requête de preuve = 0) ; secrets TOTP chiffrés ; mots de passe hachés avec Argon2id	Métadonnées ; comptes si la clé de service est volée	Alerte ; rotation de la clé de service ; révocation des comptes concernés
Journal d'audit altéré ou tronqué	La chaîne d'empreintes ne se vérifie plus : l'altération est détectée	Les dernières entrées, tant que la copie en écriture seule n'est pas à jour	Vérification planifiée de la chaîne ; comparaison avec la copie
Paramètre de sécurité abaissé	TOTP obligatoire, rôles et inscription désactivée ne se modifient pas depuis l'interface : seul un redéploiement les change	Rétention, taille maximale des fichiers	Entrée d'audit avec l'auteur ; alerte ; validation par un second administrateur en production
Client web modifié sur le serveur (risque le plus sérieux d'une application web)	Aucune garantie absolue : un client malveillant servi à l'agent pourrait lire ce que cet agent déchiffre	Tout ce qui est affiché dans l'application altérée	Empreinte SHA-256 affichée et comparée à la référence publiée ; CSP stricte ; mise à jour du client validée avant publication ; contrôle d'intégrité planifié

Ce que le dossier ne promet pas. Aucun système n'est inviolable. Le dossier garantit que le serveur ne lit pas les messages, que toute modification est tracée et détectable, et que les limites restantes (métadonnées, client servi altéré, appareil déjà compromis, photographie d'écran) sont documentées dans les sections 6.3, 9.8 et 9.9.

10. Pages et écrans de l'application

L'application comprend **18 pages** : 3 pages d'accès, 9 pages de l'espace agent et 6 pages de l'espace d'administration. Dix pages sont obligatoires pour le prototype ; les huit autres sont importantes ou souhaitables.

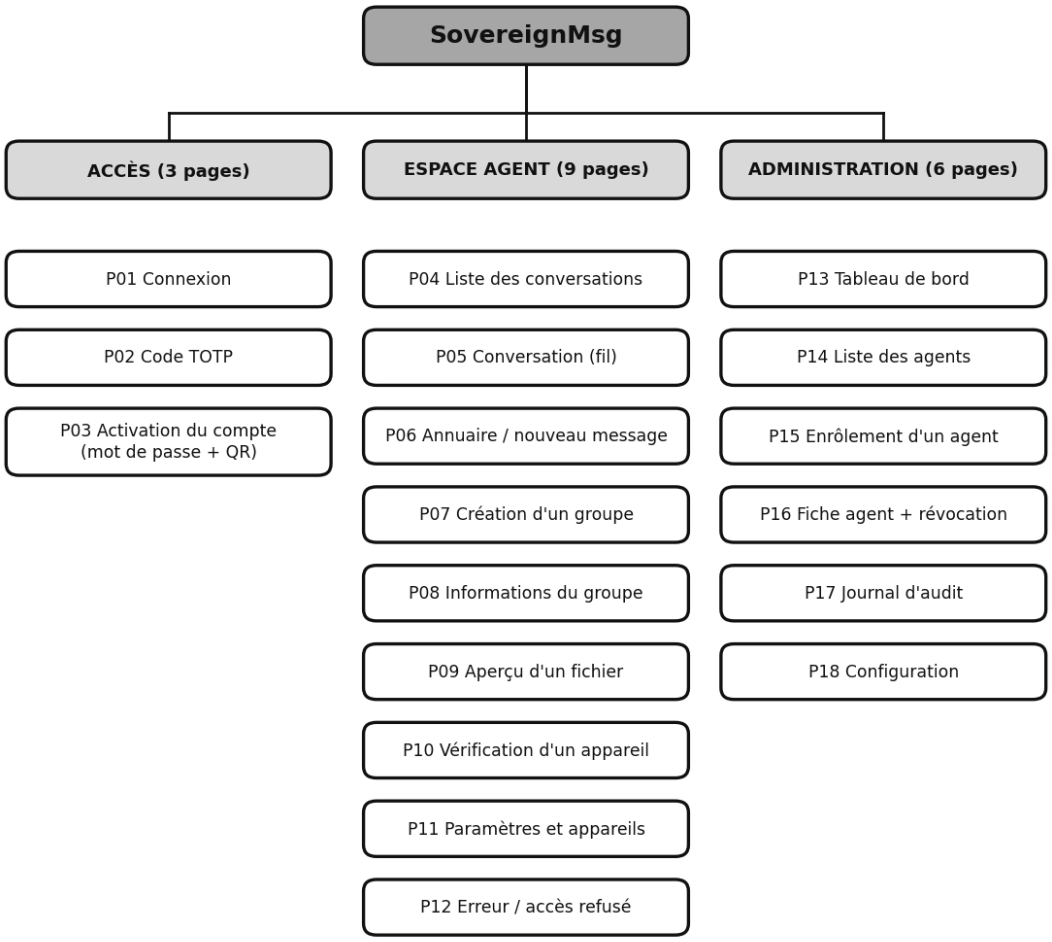


Figure 10 – Plan des pages de SovereignMsg (18 pages)

N°	Page	Acteur	Fonction	Priorité
P01	Connexion	Tous	Saisie de l'adresse et du mot de passe	Obligatoire
P02	Code TOTP	Tous	Saisie du code à six chiffres	Obligatoire
P03	Activation du compte	Agent enrôlé	Choix du mot de passe, QR code TOTP, première connexion	Obligatoire
P04	Liste des conversations	Agent, invité	Accueil : conversations, groupes, indicateurs de non-lu	Obligatoire
P05	Conversation	Agent, invité	Fil de messages, envoi, pièces jointes, niveau de classification	Obligatoire
P06	Annuaire et nouvelle conversation	Agent	Recherche d'un agent, ouverture d'une conversation directe	Obligatoire
P07	Création d'un groupe	Agent	Nom, membres, invités restreints	Obligatoire
P08	Informations du groupe	Agent	Membres, ajout ou retrait, règles du groupe	Important
P09	Aperçu d'un fichier	Agent, invité	Aperçu après déchiffrement, téléchargement	Important
P10	Vérification d'un appareil	Agent	Comparaison d'empreinte avec l'interlocuteur	Important
P11	Paramètres et appareils	Agent	Langue, appareils actifs, déconnexion, accusés de lecture	Important

N°	Page	Acteur	Fonction	Priorité
P12	Erreur et accès refusé	Tous	Compte révoqué, session expirée, droits insuffisants	Important
P13	Tableau de bord	Administrateur, RSSI	Agents actifs, en attente, révoqués, répartition par rôle	Important
P14	Liste des agents	Administrateur	Recherche, filtres par statut et rôle	Obligatoire
P15	Enrôlement d'un agent	Administrateur	Formulaire, génération du lien d'activation	Obligatoire
P16	Fiche agent et révocation	Administrateur	Détails, changement de rôle, bouton Révoquer avec confirmation	Obligatoire
P17	Journal d'audit	Administrateur, RSSI	Liste datée des actions, filtre, export	Important
P18	Configuration	Administrateur (RSSI en lecture)	Rétention, taille de fichier, niveaux de classification	Souhaitable

10.1 Principes d'ergonomie

- Disposition inspirée des messageries courantes pour réduire l'apprentissage : liste à gauche, conversation à droite sur ordinateur ; écrans successifs sur téléphone.
- Un état de sécurité toujours visible : cadenas, niveau de classification du message, statut de l'appareil vérifié.
- Messages d'erreur clairs et sans fuite d'information (par exemple, pas d'indication précisant si l'adresse existe).
- Interface en français, avec bascule vers le mooré ou le dioula pour les écrans principaux ; contrastes élevés et textes lisibles sur petit écran.

11. Plan de test et préparation des épreuves en direct

Le jury tire au sort trois épreuves parmi cinq. L'équipe prépare et répète chacune d'elles.

Épreuve	Ce que fait le jury	Preuve attendue	Préparation
Le serveur ne lit rien	Inspecte la base de données et le trafic réseau	Événements stockés de type chiffré, fichiers illisibles, trafic opaque	Requêtes SQL prêtes (annexe B.3) ; ouverture d'un fichier du volume médias ; capture réseau d'un envoi
Révocation	Révoque un agent pendant une conversation de groupe	L'agent perd l'accès, y compris aux nouveaux messages	Protocole de test à trois comptes (annexe B.2) ; mesure du délai ; démonstration du retrait des salons
Intrus	Tente d'inscrire ou de connecter un compte non enrôlé, ou de l'inviter à un groupe	Rejet à chaque tentative	Essais d'inscription, de connexion et d'invitation avec un compte inconnu
Innovation	Demande la démonstration de la fonction mise en avant	Message « Confidentiel » appliquant ses règles	Script de démonstration de 60 secondes, deux comptes ouverts
Explication du code	Désigne une fonction d'authentification ou de chiffrement et un membre	Explication claire du fonctionnement et des choix	Fiche d'explication par fonction ; chaque membre s'entraîne sur toutes

11.1 Tests automatisés (bonus de 2 points)

Test	Vérifie
Hachage et vérification des mots de passe	Aucun mot de passe en clair ; refus d'un mot de passe trop court
Validation du code TOTP	Code correct accepté, code erroné ou expiré refusé
Contrôle des rôles	Un agent ne peut pas appeler les routes d'administration
Jeton d'activation	Usage unique et expiration
Révocation	Après révocation, la connexion et les jetons existants sont refusés
Limitation des essais	Verrouillage après 5 échecs
Contrôle de non-clair en base	Aucun contenu de démonstration lisible dans la base des messages (test de bout en bout)
Blocage du proxy	Depuis l'extérieur, /_matrix/client/*/login, /_matrix/client/*/register et /_synapse/admin renvoient un refus (403 ou 404)

11.2 Liste de vérification avant dépôt

- Déploiement testé sur une machine vierge avec la seule commande docker compose up -d.
- Inspection de la base : aucun message ni fichier en clair, vérifiée avant chaque commit important.
- Aucune ressource externe chargée par le client (onglet Réseau du navigateur).
- Comptes de démonstration fictifs documentés dans le README.
- Chaque membre a répondu à l'épreuve « Explication du code » devant l'autre membre.

12. Planning et organisation

12.1 Planning du sprint

Le règlement accorde sept jours calendaires au plus. L'équipe compte deux membres et planifie six jours de travail, le septième jour servant de marge. Le budget interne est de 5 heures de développement effectif par membre et par jour, soit 60 heures-personne. Le travail des deux membres se déroule en parallèle, et une relecture croisée de 30 minutes clôt chaque journée. La figure 11 présente le planning jour par jour.

Jour	Membre 1 – infrastructure, passerelle, sécurité	Membre 2 – PWA, chiffrement, interface	Livrable de sortie
J1	Dépôt Git, Docker Compose, Synapse, PostgreSQL, Nginx	Squelette de la PWA (React, manifeste, service worker)	Une commande démarre l'ensemble ; PWA installable
J2	Passerelle : enrôlement, Argon2id, TOTP, rôles, jeton de session	Pages P01 à P03, connexion via le SDK Matrix	Connexion avec second facteur
J3	Session passerelle–Synapse, inscription désactivée, intrus rejeté, limitation des essais	Chiffrement Olm / Megolm, pages P04 et P05	Message chiffré entre deux agents ; jalon de décision de repli
J4	Révocation, API d'administration de Synapse, rotation des clés, journal d'audit chaîné	Pages P06 à P12 : groupes, fichiers chiffrés, appareils	Groupe avec fichier ; révocation démontrable

Jour	Membre 1 – infrastructure, passerelle, sécurité	Membre 2 – PWA, chiffrement, interface	Livrable de sortie
J5	Tests de sécurité automatisés, durcissement, preuves SQL, protocole de révocation (annexe B.2)	Console d'administration P13 à P17, message « Confidentiel »	Administration complète ; innovation démontrée ; gel des fonctions
J6	Essai sur machine vierge, note de sécurité, dépôt public	README, vidéo de 3 minutes, répétition des épreuves, fiches d'explication	Dossier complet déposé

Au jour 6, si les jours 1 à 5 sont tenus, l'équipe traite en option la page P18, la langue nationale (EF-62) et le mode faible connexion (EF-63).

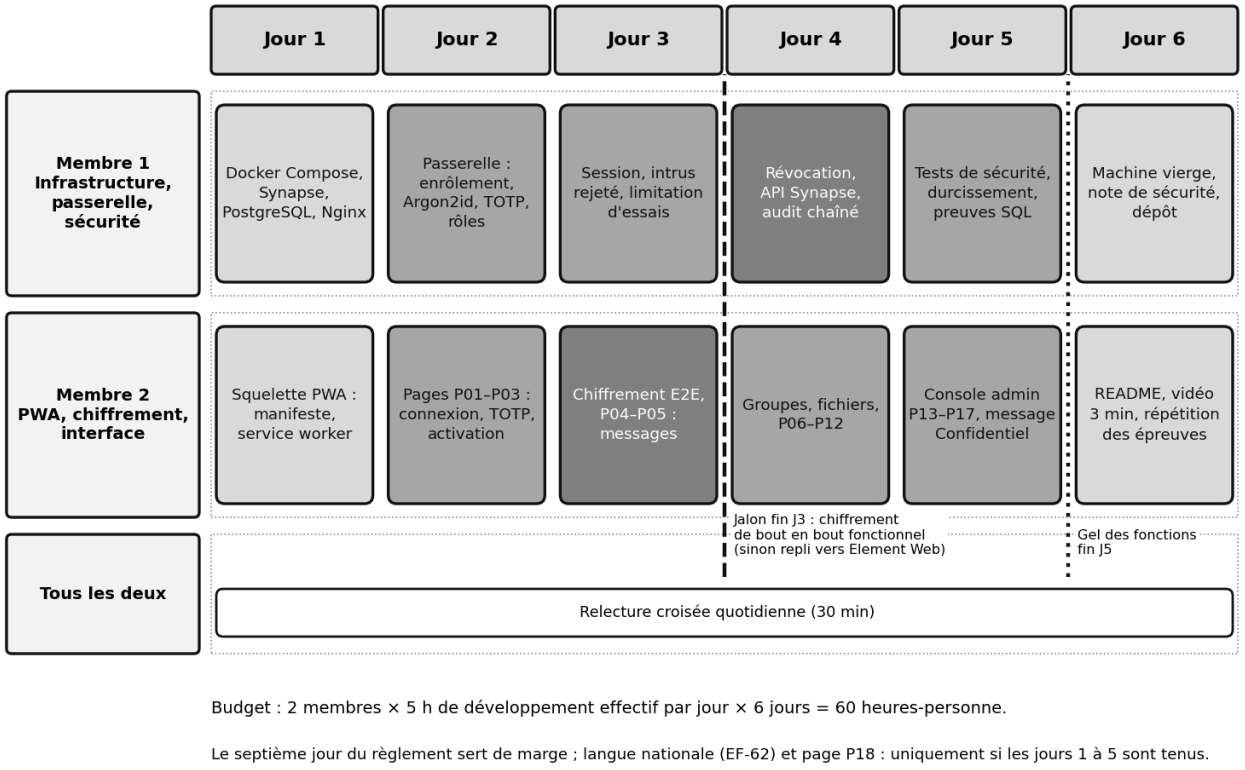


Figure 11 – Planning prévisionnel sur six jours (deux membres, 60 heures-personne)

12.2 Répartition des rôles

Rôle	Responsabilités	Livrables
Membre 1 – Infrastructure, passerelle, sécurité et services du back-office	Docker Compose, Synapse, PostgreSQL, Nginx, passerelle FastAPI, TOTP, révocation, journal d'audit chaîné, tests de sécurité, durcissement, note de sécurité	Dépôt de déploiement, API, tests de sécurité, note de sécurité
Membre 2 – Front-office (PWA), chiffrement, console d'administration et documentation	Application React installable, intégration du SDK Matrix, chiffrement, groupes, fichiers, message « Confidentiel », pages P01 à P17, README, vidéo	Pages P01 à P17, README, vidéo de démonstration

Les deux membres relisent mutuellement chaque fonction d'authentification et de chiffrement (section 12.3). La langue nationale (EF-62) et la page P18 ne sont traitées qu'au jour 6, si le planning est tenu ; en leur absence, l'objectif de score passe de 87 à 84 points (bonus de 3 points non obtenu).

12.3 Compréhension du code

Le règlement élimine toute équipe incapable d'expliquer son code ou ses mécanismes de sécurité. Chaque fonction liée à l'authentification ou au chiffrement est relue par un autre membre que son auteur, qui doit pouvoir l'expliquer à l'oral ; l'équipe prépare une fiche d'une page par mécanisme (connexion, TOTP, appel de chiffrement, révocation).

13. Gestion des risques

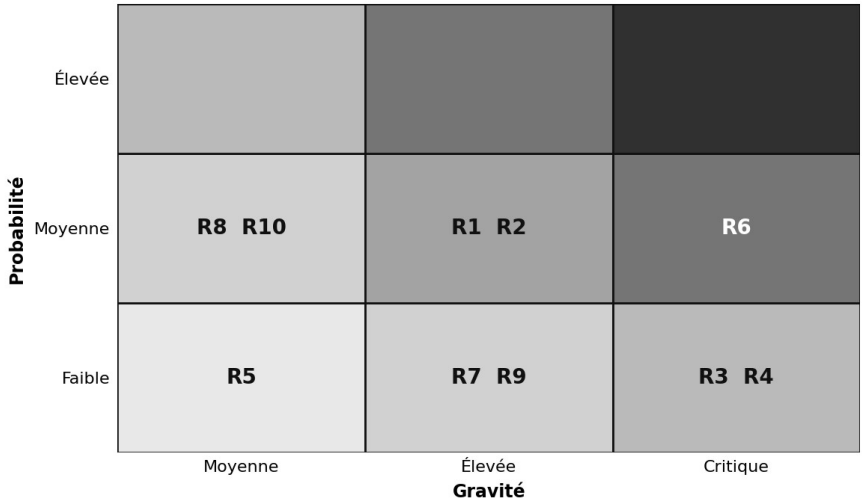


Figure 12 – Matrice des risques (probabilité et gravité)

Réf.	Risque	Probabilité	Gravité	Atténuation
R1	Manque de temps	Moyenne	Élevée	Équipe de deux : prioriser le socle ; gel des fonctions à la fin du jour 5 ; plan de repli à la fin du jour 3
R2	Difficulté d'intégration du chiffrement dans le client personnalisé	Moyenne	Élevée	S'appuyer sur le SDK, suivre ses exemples ; repli vers Element Web
R3	Message en clair côté serveur (élimination)	Faible	Critique	Aucun contenu applicatif traité par la passerelle ; inspection de la base avant chaque commit
R4	Cryptographie maison involontaire (élimination)	Faible	Critique	Aucun appel direct à des primitives ; revue de code dédiée
R5	Déploiement Docker non reproductible	Faible	Moyenne	Versions d'images figées ; essai sur machine vierge
R6	Incapacité à expliquer le code (disqualification)	Moyenne	Critique	Relecture croisée, fiches, répétition de l'épreuve
R7	Révocation perçue comme trop lente	Faible	Élevée	Mesurer le délai ; démontrer avec deux appareils ; expliquer le fonctionnement
R8	Métadonnées non documentées ou incomplètes	Moyenne	Moyenne	Tableau de la section 9.8 relu avant dépôt

Réf.	Risque	Probabilité	Gravité	Atténuation
R9	Dépendance cachée à un service tiers	Faible	Élevée	Test hors ligne ; aucune police ni CDN externe
R10	Décalage d'horloge faisant échouer le TOTP en démonstration	Moyenne	Moyenne	Synchronisation de l'heure du serveur et tolérance d'une fenêtre de 30 secondes

14. Livrables et conformité

Livrable	Contenu	Échéance	Statut
1. Fiche équipe	Nom de l'équipe, université, nom, filière et niveau de chaque membre, contacts, attestation d'inscription 2026-2027	1er novembre 2026	À faire
2. Note de pré-projet (2 pages)	Concept, architecture, protocole de chiffrement, composants et licences, niveau d'engagement, fonctions innovantes, répartition des rôles	1er novembre 2026	À faire
3. Note de sécurité (2 pages)	Menaces, protections, métadonnées visibles, limites connues	1er novembre 2026	À faire
4. Dépôt public	README.md en français (2 pages), LICENSE, code du serveur et du client, configuration de déploiement, comptes fictifs, commits progressifs	1er novembre 2026	À faire
5. Vidéo de démonstration (3 minutes)	Échange chiffré entre deux agents, révocation d'un agent, fonction innovante	1er novembre 2026	À faire

14.1 Contenu du README (deux pages au maximum)

- Concept et public visé en cinq lignes.
- Schéma d'architecture simplifié.
- Technologies utilisées, avec licence et lien pour chacune.
- Niveau d'engagement open source déclaré : Créer.
- Instructions d'installation : docker compose up -d, adresses d'accès et comptes fictifs de démonstration.
- Limites connues (capture d'écran, métadonnées, appareils hors ligne).

14.2 Plan de la note de sécurité (deux pages)

- Actifs à protéger et hypothèses de confiance.
- Menaces prises en compte (section 9.9 résumée).
- Protections mises en place : protocole, authentification, révocation, durcissement.
- Métadonnées visibles par le serveur et mesures de réduction (section 9.8).
- Limites connues et pistes d'amélioration.

15. Grille d'auto-évaluation

Le dossier est noté sur 65 points, l'entretien sur 35 points. Les bonus sont plafonnés à 10 points. L'objectif de l'équipe est de 87 points (le bonus de contribution à un projet d'origine, +5, n'est pas visé).

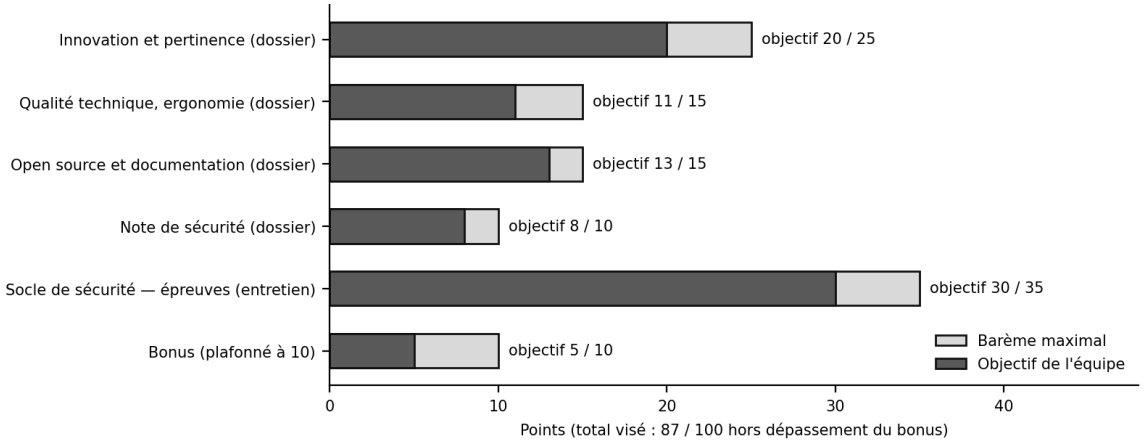


Figure 13 – Barème du jury et objectif de l'équipe

Critère	Étape	Maximum	Objectif	Comment l'atteindre
Innovation et pertinence pour l'administration	Dossier	25	20	Message « Confidentiel » démontré, contexte burkinabè (langue, faible connexion)
Qualité technique et ergonomie	Dossier	15	11	Interface claire, 18 pages cohérentes, déploiement en une commande
Engagement open source et documentation	Dossier	15	13	Composants avec licences, README et notes soignés, commits progressifs
Note de sécurité	Dossier	10	8	Menaces, métadonnées et limites présentées sans exagération
Socle de sécurité (épreuves en direct)	Entretien	35	30	Répétition des cinq épreuves, plan de repli
Bonus : langue nationale (+3), tests automatisés (+2)	Dossier	10	5	Interface mooré ou dioula, tests de sécurité
Total		**100**	**87**	

16. Conclusion et recommandations

SovereignMsg répond au challenge par une architecture simple à expliquer : un client web qui chiffre et déchiffre, une passerelle qui contrôle l'identité, un serveur Matrix qui n'achemine que du texte chiffré, le tout déployé par une commande. L'innovation repose sur une idée concrète et démontrable : la classification des messages, complétée par la langue nationale et la faible connexion si le temps le permet.

Recommandations pour l'équipe :

- Utiliser un protocole complet et éprouvé tel quel ; ne jamais composer soi-même des primitives cryptographiques.
- Terminer le socle de sécurité (chiffrement, enrôlement, TOTP, révocation) avant toute fonction d'innovation.
- Prendre la décision de repli à la fin du jour 3 si le chiffrement du client n'est pas fonctionnel.
- Figer les versions des dépendances (fichiers de verrouillage) et relire la licence de toute dépendance ajoutée avant le dépôt.
- Tester le déploiement sur une machine vierge, puis préparer l'entretien : chaque membre doit savoir expliquer chaque mécanisme.

- Documenter honnêtement les limites : le jury valorise une analyse lucide plus qu'une promesse absolue.

Annexe A – Note Synapse et squelette du README

A.1 Texte de précision (à reprendre tel quel dans le README et le dossier)

> **Note sur Synapse**
> Le serveur de messagerie utilisé est Matrix Synapse, logiciel libre (AGPL-3.0) installé et exploité par l'administration elle-même. Ce n'est pas un service commercial ou hébergé. Le chiffrement de bout en bout (Olm / Megolm, bibliothèque vodozemac) est activé par défaut pour tous les salons ; le serveur ne stocke que du texte chiffré. La fédération avec d'autres serveurs est désactivée et aucun service tiers n'est nécessaire.

A.2 Squelette du README (deux pages au maximum, en français)

Section	Contenu
Concept	SovereignMsg : messagerie instantanée souveraine pour les agents de l'administration burkinabè
Note sur Synapse	Texte de la section A.1
Architecture	Schéma simplifié : client web, passerelle d'identité, Synapse, PostgreSQL, Nginx
Technologies et licences	Tableau de la section 9.2 avec licences et liens
Niveau d'engagement	Créer
Installation	docker compose up -d, adresse d'accès, comptes fictifs de démonstration
Limites	Capture d'écran, métadonnées visibles, appareils hors ligne

Une version prête à compléter du README est fournie en fichier séparé (README.md).

Annexe B – Révocation en direct et inspection de la base

B.1 Configuration obligatoire de Synapse

Ces réglages conditionnent la réussite des épreuves. Les noms exacts des paramètres sont à confirmer dans la documentation de la version retenue.

Paramètre	Valeur	Pourquoi
encryption_enabled_by_default_for_room_type	all	Aucun salon créé sans chiffrement : sinon des messages en clair apparaîtraient en base (élimination)
enable_registration	false	Épreuve Intrus : aucune inscription publique
federation_domain_whitelist	liste vide	Aucune fédération, aucun serveur tiers
presence (activée)	false	Réduit les métadonnées
Durée de conservation des adresses IP	courte	Réduit les métadonnées
Proxy Nginx : chemin /_synapse/admin	bloqué depuis l'extérieur	L'API d'administration n'est appelée que par la passerelle, en réseau interne

Paramètre	Valeur	Pourquoi
password_config	Activé (pour l'API d'administration interne), mais route /login bloquée par Nginx	Le compte administrateur dédié de la passerelle obtient son jeton par une connexion par mot de passe, et le plan de repli en dépend. Les comptes des agents n'ont pas de mot de passe utilisable. Le blocage se fait au niveau du proxy (Nginx), pas dans Synapse.
Proxy Nginx : /_matrix/client/*/login et /_matrix/client/*/register (r0, v3, unstable)	bloqués depuis l'extérieur	Épreuve Intrus : un appel direct à Synapse depuis Internet reçoit un refus (403 ou 404) ; seule la passerelle, en réseau interne, peut s'y connecter
Port client de Synapse	non publié, réseau Docker interne	Seul le port 443 de Nginx est exposé
jwt_config	absent	Le client n'utilise pas la connexion par JWT (l'identifiant m.login.jwt est déprécié) : la passerelle obtient le jeton par l'API d'administration

B.2 Protocole de test de la révocation (épreuve du jury)

Scénario : l'agent A est dans un groupe avec l'agent B (et un témoin C). L'administrateur révoque A ; B envoie ensuite un nouveau message ; A ne doit pas pouvoir le lire. Ce test est à exécuter sur l'instance réelle, avec trois navigateurs ou profils, puis à répéter avant le dépôt et avant l'entretien.

Étape	Action	Résultat attendu
1	A, B et C sont connectés dans le groupe G. B envoie un message de contrôle M0	A et C lisent M0 (preuve de départ)
2	L'administrateur révoque A depuis la fiche agent (P16) ; noter l'heure t0	Statut « révoqué » ; entrée dans le journal d'audit
3	Observer A : action quelconque dans l'application	Requête refusée, session fermée ; délai mesuré inférieur à 10 secondes
4	Attendre que le client de B ait reçu le départ de A, puis B envoie M1	B n'a pas d'erreur ; M1 part avec une nouvelle clé de groupe
5	C lit M1	M1 lisible par C
6	A tente de lire M1 (nouvelle connexion refusée, ou ancienne session hors ligne)	A ne reçoit pas M1 ; même avec ses anciennes clés, M1 reste illisible
7	Comparer en base l'identifiant de session de M0 et de M1 (requête B.3)	Deux identifiants de session différents

Points de vigilance du test

Si B envoie M1 avant que son client ait appris le départ de A, M1 peut encore utiliser l'ancienne clé de groupe : c'est pourquoi l'étape 4 attend l'événement de départ. À montrer au jury : le retrait d'abord, l'envoi ensuite.

Les messages reçus par A avant la révocation (M0) restent lisibles sur son appareil : c'est la limite connue, déjà documentée à la section 9.4.

Le comportement exact de la désactivation d'un compte (sortie automatique des salons, suppression des appareils) est à vérifier sur la version de Synapse retenue ; sinon la passerelle retire explicitement A des salons.

B.3 Requêtes SQL d'inspection de la base Synapse

À exécuter dans la base de Synapse, par exemple avec docker compose exec db psql (utilisateur et nom de base à adapter). Les noms de tables et de colonnes sont ceux d'un Synapse standard et sont à vérifier sur la version retenue ; répéter ces requêtes avant le dépôt.

1. Types d'événements stockés : les messages doivent apparaître sous le type chiffré.

```
SELECT type, COUNT(*) FROM events GROUP BY type ORDER BY 2 DESC;
```

2. Aperçu brut des derniers messages : seuls des champs de chiffrement doivent apparaître (algorithme, texte chiffré, identifiant de session), jamais le texte du message.

```
SELECT e.type, e.origin_server_ts, LEFT(j.json, 300)
FROM events e JOIN event_json j USING (event_id)
WHERE e.type = 'm.room.encrypted'
ORDER BY e.origin_server_ts DESC LIMIT 3;
```

3. Preuve négative : aucun événement ne doit contenir de texte lisible de message. Résultat attendu : 0.

```
SELECT COUNT(*) FROM event_json
WHERE json LIKE '%"msgtype"%' OR json LIKE '%"body"%';
```

4. Identifiant de session de groupe par message (étape 7 du test de révocation) :

```
SELECT e.origin_server_ts,
       (j.json::json)->'content'->>'session_id' AS session
FROM events e JOIN event_json j USING (event_id)
WHERE e.type = 'm.room.encrypted'
ORDER BY e.origin_server_ts;
```

B.4 Autres preuves à montrer

- Fichiers : ouvrir un fichier du volume médias dans un éditeur ou avec la commande file ; le contenu doit être illisible.
- Trafic : dans l'onglet Réseau du navigateur, montrer que les requêtes d'envoi contiennent uniquement des champs chiffrés.
- Aucun message de démonstration posté en clair par le script d'amorçage (sinon la requête 3 ne renvoie pas 0).
- Intrus direct : depuis un terminal extérieur au serveur, lancer une requête POST vers /_matrix/client/v3/login (et /_synapse/admin/v1/users) ; le proxy doit répondre par un refus (403 ou 404). Expliquer que la passerelle est la seule porte d'entrée et que la règle du proxy est testée automatiquement.

Annexe C – Fiches d'explication du code

Chaque membre doit pouvoir répondre à ces questions sans notes. Répétition conseillée : chacun explique les trois fiches à l'autre membre, devant le code, en trois minutes par fiche.

Question	Réponse en une minute	À savoir aussi
Pourquoi vodozemac ?	C'est l'implémentation en Rust des protocoles Olm (conversations directes) et Megolm (groupes) de Matrix, utilisée par le SDK Matrix. Elle est compilée en WebAssembly pour tourner dans le navigateur. L'équipe n'écrit aucune cryptographie : elle appelle la bibliothèque.	Olm établit une session entre deux appareils ; Megolm utilise une clé de session par expéditeur, transmise aux membres via Olm. Ne pas affirmer que la bibliothèque a été auditée sans l'avoir vérifié. Expliquer pourquoi @noble seul ne suffisait pas (voir section 5.1).

Question	Réponse en une minute	À savoir aussi
Comment fonctionne le TOTP dans FastAPI ?	À l'enrôlement, la passerelle génère un secret aléatoire (pyotp.random_base32), l'affiche sous forme de QR code (URI otpauth) et le stocke chiffré. À la connexion, après le mot de passe Argon2id, elle vérifie le code à six chiffres avec pyotp, qui recalcule le code à partir du secret et de l'heure par tranches de 30 secondes (norme RFC 6238).	Fenêtre de tolérance d'une tranche (valid_window=1) ; horloge du serveur synchronisée ; limitation des essais ; un code déjà utilisé n'est pas accepté deux fois si l'anti-rejeu est implémenté. Fonction à connaître : celle de vérification dans la passerelle.
Comment l'API d'administration de Synapse révoque-t-elle un appareil ?	La passerelle, après avoir marqué l'agent « révoqué » et écrit l'audit, appelle l'API d'administration de Synapse avec un jeton d'administration interne : désactivation du compte et suppression des appareils. Les jetons d'accès associés sont invalidés, donc la requête suivante de l'agent est refusée.	Cette API n'est jamais exposée à l'extérieur (bloquée au proxy). Le renouvellement de la clé de groupe est fait par les clients des autres membres au départ de l'agent. Limite : messages déjà déchiffrés sur l'appareil. Vérifier les noms exacts des appels dans la documentation.
Comment prouver que le serveur ne lit rien ?	Les messages sont chiffrés dans le navigateur avant envoi ; la base ne contient que des événements de type chiffré. Montrer les requêtes de l'annexe B.3 et le résultat 0 de la preuve négative.	Les noms de groupes et la liste des membres restent visibles : les citer comme limites connues.
Pourquoi une passerelle d'identité ?	Synapse ne fournit pas à lui seul l'enrôlement par administrateur, le TOTP et les rôles dont le challenge a besoin. La passerelle les ajoute sans modifier Synapse, puis demande un jeton de session pour l'agent.	Le mot de passe est haché avec Argon2id, conçu pour résister à la force brute. L'inscription publique est désactivée dans Synapse.

Format de la répétition : tirage au sort d'une fiche et d'un membre, réponse en trois minutes, questions de relance de l'autre membre. Noter les hésitations et recommencer jusqu'à ce que chaque membre réponde sans aide.

Annexe D – Glossaire

Terme	Définition
Chiffrement de bout en bout (E2EE)	Les messages sont chiffrés sur l'appareil de l'expéditeur et déchiffrés uniquement sur celui du destinataire
Olm / Megolm	Protocoles de chiffrement de Matrix : Olm pour les conversations directes, Megolm pour les groupes
vodozemac	Bibliothèque de chiffrement qui implémente Olm et Megolm
Synapse	Serveur Matrix open source utilisé comme moteur de messagerie
Passerelle d'identité	Service propre au projet qui contrôle l'enrôlement, l'authentification forte, les rôles, l'audit et la révocation
TOTP	Code à usage unique renouvelé toutes les 30 secondes, généré par une application d'authentification
Argon2id	Algorithme de hachage de mots de passe conçu pour résister aux attaques par force brute
Métadonnées	Informations sur les échanges (qui, quand, taille) distinctes de leur contenu
Révocation	Retrait immédiat des droits d'accès d'un agent sur tous ses appareils

Terme	Définition
CSP	Politique de sécurité des contenus : règle du navigateur limitant les ressources et scripts autorisés
Docker Compose	Outil qui démarre plusieurs conteneurs avec une seule commande
RSSI	Responsable de la sécurité des systèmes d'information
MTDPCE / DGTD	Ministère de la Transition Digitale, des Postes et des Communications Électroniques / Direction Générale de la Transformation Digitale